

SEE ALSO

Press release of May 19, 2025

Provision of June 22, 2023

Press release of February 3, 2023

Provision of February 2, 2023

- English version

[doc. web n. 10127930]

Provision of April 10, 2025

Register of provisions

n. 232 of April 10

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting today, attended by

Prof. Pasquale Stanzione, President, Prof.

Ginevra Cerrina Feroni, Vice President, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Dr. Claudio Filippi - Acting Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European

Parliament and of the Council, of April 27, 2016, concerning

the protection of natural persons with regard to the

processing of personal data, as well as the free

movement of such data and repealing Directive

95/46/EC (General Data Protection Regulation, hereinafter "Regulation");

HAVING REGARD to the Code regarding the protection of personal data

(legislative decree June 30, 2003, n. 196), as

amended by legislative decree August 10, 2018, n. 101, containing

provisions for the adaptation of the national

legislation to the aforementioned Regulation (hereinafter

"Code");

HAVING REGARD to Regulation n. 1/2019 concerning

internal procedures of external relevance,

aimed at carrying out the tasks and

exercising the powers assigned to the Guarantor for the

protection of personal data, approved by

resolution n. 98 of April 4, 2019, published in

G.U. n. 106 of May 8, 2019 and in www.gpdp.it, doc.

web n. 9107633 (hereinafter "Guarantor Regulation

n. 1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary

General pursuant to Article 15 of the Guarantor

Regulation n. 1/2000;

REPORTING Attorney Guido Scorza;

1. INTRODUCTION

The procedure originated from an investigative activity

initiated ex officio by the Authority following

the publication of press news and preliminary

investigations conducted on the Replika service

(<https://replika.com/>), a chatbot with

written and vocal interface, developed and managed

by the American company Luka Inc. (hereinafter

"Luka" or the "Company") and based on a

generative artificial intelligence system.

Replika is presented as a chatbot capable of improving the user's mood and emotional well-being, helping them understand their thoughts and feelings, track their mood, learn coping skills (i.e., stress control), calm anxiety, and work towards goals such as positive thinking, stress management, socialization, and seeking love. Replika generates a "virtual companion" that the user can choose to configure as a friend, therapist, romantic partner, or mentor.

Replika uses a Large Language Model (LLM) system that is constantly fed and refined through interaction with users.

For the purposes of this provision, "generative artificial intelligence" refers to the field of artificial intelligence that focuses on creating new and original content based on input data in response to user requests (prompts) through the use of predominantly neural-type algorithms. A "neural network" is defined as a standard computational model applicable in various contexts that allows for the recognition of objects, shapes, or patterns within a given data set (for example, a human face in a photograph).

Generative artificial intelligence algorithms are employed in a wide range of applications, including the recognition and generation of images, voice or musical tracks, texts, and videos.

An example of generative artificial intelligence is large language models (Large Language Models). For the purposes of this provision, a "Large Language Model" refers to a probabilistic model of a natural language, such as English or Italian, based on the assumption that all natural languages are highly redundant and correlated; this leads to the LLM's ability to identify the word or symbol that is, probabilistically, immediately subsequent to a given data point.

In light of the aforementioned elements, the Guarantor has initiated an ex officio investigation noting that the processing of personal data by Luka within the Replika service may lead to a violation of the regulations regarding personal data, particularly with reference to: the privacy policy and the obligations provided for in terms of transparency; the absence in the privacy policy of a specifici per garantire che le interazioni degli utenti con il chatbot siano conformi alle normative vigenti in materia di protezione dei dati personali, con particolare attenzione alla tutela dei minori e dei soggetti vulnerabili;

- sviluppare e implementare un sistema di segnalazione per consentire agli utenti di riportare contenuti inappropriati, garantendo che tali segnalazioni vengano gestite in modo tempestivo ed efficace;
- condurre sessioni di formazione per il personale e i collaboratori coinvolti nella gestione del servizio Replika, al fine di sensibilizzarli sulle problematiche relative alla protezione dei dati e alla tutela dei minori.

3. VALUTAZIONE DELL'AUTORITÀ

L'Autorità ha preso atto delle comunicazioni e delle iniziative intraprese da Luka, evidenziando che, sebbene siano stati compiuti passi significativi verso la conformità alle prescrizioni, permangono delle criticità che necessitano di ulteriori interventi. In particolare, l'Autorità ha sottolineato la necessità di garantire che le misure di verifica dell'età siano efficaci e che il sistema di segnalazione per contenuti inappropriati sia implementato in modo da garantire una risposta adeguata e tempestiva alle segnalazioni degli utenti.

4. CONCLUSIONI

In conclusione, l'Autorità ha ribadito l'importanza di garantire un ambiente sicuro per gli utenti, in particolare per i minori, e ha invitato Luka a continuare a collaborare attivamente con l'Autorità per garantire il rispetto delle normative in materia di protezione dei dati personali. L'Autorità si riserva di monitorare l'evoluzione della situazione e di adottare ulteriori provvedimenti qualora fosse necessario.

****Purpose of Moderation of Inappropriate Content,****

according to the best state of the art;

- ensure compliance with the Regulation by, inter alia, updating the register of processing activities, reviewing and updating data protection impact assessments (DPIA), as well as updating the privacy notice related to the service, in order to increase the degree of transparency for users.

The Company, in a note dated March 31, 2023 (prot. no. 55533/23), requested the revocation of the corrective measure of the provisional limitation imposed by urgent measure no. 39/2023, specifying:

- that it designed the Replika service to limit the extent of personal data processing, in accordance with the principles set out in Article 5 of the Regulation, including i) minimization of the collection of user registration data (name, email address, date of birth - to verify age - and any third-party login data); ii) the adoption of data retention and deletion procedures that achieve a balance between the need to provide the user with a smooth experience and the need to minimize the personal data that remains accessible; iii) the design of proprietary artificial intelligence (AI) models to respond to users; iv) the non-sharing of user conversations with third parties other than the Company's essential service providers, bound by confidentiality obligations; v) the implementation of strict controls designed to limit access to personal data by its personnel; vi) the non-use of user conversations for advertising or marketing purposes;
- that it does not offer the service to minors and bases the processing of users' personal data on the legal basis of contractual execution;
- that it has implemented, following the Authority's provision, numerous measures aimed at preventing minors from accessing the service in violation of the Company's terms;
- that it has listed its mobile application in the Apple App Store with an age rating of 17 or older, which is the highest age rating allowed by Apple;
- that it does not collect special categories of personal data, given that the sharing of special categories of personal data by users during interaction with the chatbot occurs spontaneously and must therefore be qualified as covered by explicit consent to processing, in accordance with Article 9 of the Regulation;
- that it takes its responsibilities regarding data protection seriously and has integrated data protection into the design of the service, in accordance with Article 25 of the Regulation and continues to "develop and improve its policies and procedures to provide users with a consistent, safe, and rewarding experience."

With specific reference to the Authority's provision, the Company stated:

- that it promptly blocked access to the Replika service for individuals located in Italy;
- that it has strengthened measures to prevent access to the service by individuals under 18 years of age, particularly through: i) the introduction of an age gate on all registration pages for the service requiring the indication of a date of birth of 18 years or older for access to the service; ii) the provision of a "cooling-off period," in line with the guidelines of data protection authorities and best practices, to prevent minors from entering a different date of birth when the system denies access to the service; iii) the initiation of activities aimed at improving automated processes for content control (reporting individuals likely under 18 years of age and preventing the use of the service until age verification through more robust means);

- that it has updated its privacy policy to address the transparency issues identified by the Authority;
- that it continues to develop and refine its content moderation practices to avoid harm to users, particularly through the creation of a trust and safety program to prevent the chatbot from being involved in offensive or harmful conversations;
- that it has restricted access to sexual or other adult content conversations to active users as of February 1, 2023, excluding the availability of such types of conversations to new users;
- that it continues to commit to ensuring compliance with the Regulation with the support of an external consultant in the field of personal data protection. The commitments undertaken by the Company include: i) updating and maintaining the Company's register of processing activities; ii) the review and update of data protection impact assessments (DPIA), which include documentation of data protection processes by design and by default; iii) the refinement and verification of the Company's security policies and procedures; iv) the review of the Company's governance regarding data protection (including the possibility of appointing a DPO following the expansion of the Company's activities in the European Union). The Company, in a note dated April 26, 2023 (prot. 68896/23), submitted a second request for the revocation of the corrective measure of the provisional limitation imposed by urgent measure no. 39/2023, reiterating the measures taken, as already illustrated in the previous note. The Company, in a note dated June 14, 2023 (prot. no. 93675/23), following up on what was discussed during the hearing held on May 31, 2023, reiterated that it had promptly responded to measure no. 39/2023, immediately blocking access to Replika in Italy and that it had implemented adequate measures in response to the issues raised by the Authority in the aforementioned measure. The Company also expressed its commitment to prevent users located in Italy from engaging in sexually explicit conversations, preparing, once reactivated, two versions of the Replika service: a free version and a paid version containing romantic, but not sexual, content. The introduction of a paid "romantic" version, according to the Company, involves an additional age verification based on the entry of the user's payment card details, in line with the latest market standards for age verification mechanisms.

The Company, in a note dated July 14, 2023 (prot. no. 109176/23), communicated that it had complied with the requests set out in points 1-6 of measure no. 280/23 and, in particular, stated:

1. in relation to the information referred to in point 1 of measure no. 280/23, that it had implemented an updated privacy policy in the registration process and prior to access to the service and that such information would be shown to Italian users at the time of reactivation of the service;
2. with reference to the age gate mechanism referred to in point 2 of measure no. 280/23, that it had implemented an age verification system on all registration pages and that this system would be applied at the time of reactivation of the service;
3. with reference to the cooling-off period referred to in point 3 of measure no. 280/23, that it had implemented a cooling-off period to prevent minors from attempting to access the service again by entering a different date of birth. This period - lasting 24 hours - is expected to be managed through recognition of the credentials of a minor user's account and consequent inhibition of the entry of a different date of birth and ii) through the installation of a cookie suitable to prevent minor users from re-entering a date of birth different from the same browser. The Company stated that this cooling-off period would be applied at the time of reactivation of the service;
4. regarding the exercise of the rights referred to in point 4 of measure no. 280/23, to provide users with a simple and effective method to exercise their rights regarding data protection, including the right to object to the processing of their personal data and the rights to request access, rectification, and deletion of their data and that this mechanism would be applied at the time of reactivation of the service;
5. regarding the request to prepare a plan for the development of an age verification mechanism during the registration phase referred to in point 5 of measure no. 280/23, to have implemented processes to prevent access to minors under 18 years of age, including a linguistic analysis mechanism that requires users to reconfirm their age through the age gate process when users identify themselves as minors under 18 years of age. In the absence of a date of birth that meets the age gate, the user cannot access the service. The Company stated that these processes would be

applied in Italy at the time of reactivation of the service;

6. regarding the request to prepare a plan for the development of an age verification mechanism during the use of the service referred to in point 6 of measure no. 280/23, to have implemented functions that allow users to report inappropriate content to prevent the Replika chatbot from re-presenting it, such as the ability to flag specific responses as inappropriate and to provide feedback on the user experience during the session. The Company stated that these functions would be applied in Italy at the time of reactivation of the service. Luka submitted, along with the note of July 14, 2023, a copy of the updated privacy policy as of June 12, 2023.

3. INSTRUCTIONAL ACTIVITIES

Parallel to the adoption of the precautionary measure, the Authority proceeded to acquire the elements deemed necessary for the conduct of the investigation through a request for information, pursuant to Articles 58, par. 1, lett. e), of the Regulation and 157 of the Code.

By note dated April 6, 2023 (prot. n. 58925/23), the Guarantor sent a request for information to Luka, asking for clarifications regarding the functioning of Replika (categories of personal data processed and source from which they are collected; methodology applied for collection; methods of processing the collected data; location of data storage; security measures adopted; processing of user data for the purpose of training the system or for other purposes pursued by Luka), the processing of personal data of users (legal basis; retention period; minimum age to access the service provided by Replika; DPIA; appointment of a representative pursuant to Article 27 of the Regulation; procedures for managing the rights referred to in Articles 12–22 of the Regulation; legal basis and adequacy guarantees referred to in Chapter V of the Regulation, where applicable; clarifications regarding automated processing pursuant to Article 22 of the Regulation), and the age verification measures for access to the service at the date of notification of the urgent measure no. 39/23.

In response to this request, by note dated May 8, 2023 (prot. n. 74173/23), the Company, after initially claiming to have a single establishment in the European Union in the Netherlands, represented:

- that it uses the messages and content that the user sends to the chatbot to enable conversations with that user (the “Chatbot Interaction”). With reference to the Chatbot Interaction, the content of the database may include basic profile information, conversation topics, questions that the user may ask, and selected preferences or interests. When a user sends a message, the model analyzes the text to allow the chatbot to generate a response based on the latest messages in the conversation. The Company also specified that it uses a database that contains all the information sent through the chat to create de-identified data and refine the LLM model that forms the basis of the chatbot (“Model Development”). The part of the database used as a source to create de-identified data is limited to: 1) the “Reactions” of users (“like,” “dislike,” “love,” “funny,” “meaningless,” or “offensive”), if the user chooses to make such a selection; 2) the “Feedback” on user satisfaction levels in the conversation (“happy,” “neutral,” or “sad”); 3) the “Snippets,” that is, small parts of user conversations that provide context for interpreting the Reactions and Feedback. The information used by the Company for the Model Development does not identify specific individuals and cannot be associated with specific individuals (“De-identified Data”) as any personal identifier (such as names, addresses, emails, phone numbers, and identification numbers) that may be contained in the conversation snippets is removed, and the snippets are “mixed” in a randomized manner;
- that it collects all the personal data described above from user interactions with the service;
- that it employs a collection system (of “Reactions,” “Feedback,” and “Snippets”) and real-time processing of user interactions with the chatbot using webhooks, that is, automated tools that capture such information and send it to the Company’s servers;
- that it follows, in the processing of “De-identified Data” for Model Development, the following phases: 1) data collection, as described above; 2) pre-processing consisting of cleaning, structuring, and removing any personal identification data from the data itself, in order to safeguard privacy (through aggregation and randomization techniques); 3) labeling of the pre-processed data; 4) analysis and development to evaluate the performance of the LLM model, identify patterns, and develop filters that

- prevent the model from producing output with inappropriate content; 5) testing and validation (regular tests and validation against predefined criteria);
- that it stores personal data on encrypted databases hosted by Amazon Web Services, Inc. in the United States;
 - that it does not use the personal data provided by users for Model Development;
 - that it employs technical and organizational measures to protect the security of personal data and "De-identified Data" from unauthorized access, use, and disclosure. Such measures include encryption, access controls, vulnerability management, pre-processing and anonymization of "Snippets," "Reactions," and "Feedback," training, and possible disciplinary measures in case of non-compliance with the measures by the Company's personnel;
 - that it relies on the contractual legal basis for the "Chatbot Interaction" as the processing of user data is necessary for the provision of the service, in accordance with the provisions of the Terms of Service. This processing includes the creation and maintenance of user account profiles, facilitating payments and transactions, and processing data entered by users to generate the chatbot's response;
 - to rely on the legal basis of legitimate interest for the "Model Development";
 - to retain data for "the time it reasonably deems necessary to provide users with a safe, enjoyable, and effective experience on the platform," in compliance with the principle of minimization;
 - to retain "Chatbot Interaction" data for "a period sufficient to facilitate the recall of information to ensure users have uninterrupted conversations with the chatbot, in line with user expectations";
 - to retain [without further specifications, ed.] user data to create "De-identified Data" for "Model Development";
 - that the minimum age required to use the Replika service is 18 years;
 - that there is no contradiction between the previous point and the statement contained in the Company's privacy policy, which states: "We do not knowingly collect Personal Data from children under the age of 13. If you are under 13, please do not submit any Personal Data through the Services," as this statement has been included as required under U.S. federal law (COPPA);
 - that the Replika mobile application included an age gate that prevented minors under 18 from accessing the service even before the decision of the Authority on February 2, 2023. The Company has also listed its application in the Apple App Store with an age rating of 17 or older, which is the highest age rating allowed by Apple;
 - that all adult content has been placed behind a paywall, out of reach of minors;
 - that following the decision of February 2, 2023,

the Company voluntarily enhanced measures to prevent individuals under 18 from accessing the service;

- that it has not appointed a representative pursuant to Article 27 of the Regulation as the Company has an establishment in the European Union;
- regarding the exercise of the rights of data subjects, relevant information is provided through a privacy policy published on the Company's website and in the App. Access, rectification, and deletion can be requested by users, who may also object to and limit the processing of any personal data not necessary for the provision of the service. Requests are evaluated on a case-by-case basis;
- that it does not engage in any profiling of data subjects nor make automated decisions that have legal effects or similar significance;
- that it collects personal data directly from users and does not transfer it from Italy or

the European Union pursuant to Chapter V of the Regulation and has entered into agreements for data processing with data processors, which include standard contractual clauses, where required;

- for the purpose of content control, it has trained its models to avoid the emergence and escalation of inappropriate content or inappropriate responses. In this process, the Company uses open-source datasets specifically designed and made available to the artificial intelligence research community to improve the safety and robustness of machine learning models. The Company has also developed, and continues to refine and improve, filters that recognize keywords, phrases, and patterns associated with harmful behaviors, such as self-harm, insult, or murder. The filters activate the LLM model to respond appropriately to such content, for example, by changing the topic of conversation or providing users with self-help resources. The Company also uses human reviewers both in evaluating the AI model and in developing the filters;
- to use, for the control of inappropriate content or content contrary to the terms of service of the application, other methods including: 1) placing so-called romantic content behind a paywall and disabling sexually explicit content for new users; 2) allowing users to report in real-time certain content or conversations as offensive and using such reports to improve the models and prevent them from developing similar content in the future; 3) prohibiting users, in the terms of service, from uploading illegal, harmful, and threatening content.

data outside your country”) non specificava chiaramente se i dati personali degli utenti fossero trasferiti al di fuori dello Spazio Economico Europeo (SEE) e non forniva dettagli sulle garanzie adeguate previste dal Regolamento.

In merito agli obblighi di informativa, l'Autorità ha osservato che la privacy policy non forniva informazioni sufficienti e chiare riguardo ai diritti degli interessati, in particolare in relazione ai diritti di accesso, rettifica, cancellazione e opposizione al trattamento dei dati personali. Inoltre, non era presente un'informativa adeguata riguardo al diritto di revocare il consenso, né era chiarito come gli utenti potessero esercitare tali diritti.

Infine, l'Autorità ha evidenziato che, alla data del 2 febbraio 2023, la privacy policy non conteneva informazioni aggiornate riguardo ai contatti del Responsabile della Protezione dei Dati (DPO) e non era presente un meccanismo chiaro per la segnalazione di eventuali violazioni della privacy.

In conclusione, l'Autorità ha ritenuto che la Società avesse violato gli obblighi di trasparenza e informativa previsti dal Regolamento, in particolare in relazione agli articoli 5, 6 e 12, e ha avviato il procedimento per l'adozione di provvedimenti correttivi e sanzionatori.

****Information in the U.S.A., a jurisdiction in which the privacy laws may not be as comprehensive as those in the country where you reside or are a citizen****

is in open contradiction to what the Company stated in the note dated May 8, 2023 (prot. no. 74173/23), where it is asserted that, since the criterion of establishment in the European Union does not apply, no transfer of personal data from the European Union (specifically, from Italy) to the United States of America could be configured, pursuant to Chapter V of the Regulation;

- in section 6 titled "Your data protection rights," the privacy policy provided specific information regarding the right under Article 22 of the Regulation, although the provision was not expressly referenced. This reference (no longer present in the version dated March 22, 2023) was capable of leading the user to believe that their personal data was subject to automated decision-making in violation of the principles of transparency and fairness. This circumstance was denied by the same holder in the response note (prot. 74173/23), where it was stated that "although the chatbot relies on automated processes to generate responses, the Services do not make decisions based on profiling that have legal effects or similar significance under Article 22 of the Regulation."

In light of the above, the Authority contested Luka for the possible violation of Article 5, paragraph 1, letter a), 6, 12, and 13 of the Regulation, given that, as of February 2, 2023, the privacy policy related to the Replika service was found to be non-compliant with the obligations and general principles regarding transparency and was provided in a manner and timeframe that did not allow for prompt viewing by users.

With regard, finally, to the absence of age verification mechanisms for minors, the Authority contested the lack of measures to ensure specific protection for minors concerning access to and use of the Replika service as of February 2, 2023. In particular, the absence of was noted:

- a user age verification procedure (the system only required name, email, and gender) resulting in the risk of presenting minors with responses inappropriate for their level of development and self-awareness, including sexually explicit content;
- mechanisms for prohibition or blocking even in the face of user statements that made their minor age evident, as well as the presentation of responses by the chatbot that were clearly in contrast with the protections that should be ensured for minors and, more generally, for all more vulnerable individuals.

The Authority, in the initiation of the procedure, acknowledged that the Company implemented age verification mechanisms following the request made by the Guarantor as part of the provisional limitation measure adopted urgently on February 2, 2023. In particular, during the discussions that followed the adoption of the aforementioned measure and with specific reference to the aspect of age verification, the holder represented that they had implemented an age gate on all registration pages for the Services aimed at limiting access to only adult users and that the age verification mechanism includes a "cooling-off period" aimed at preventing the user, upon determining the impossibility of accessing by entering real personal data, from immediately entering a different birth date suitable for allowing them to access the service. The Company also represented that a process was under development to use language analysis to identify and prevent the use of the Services by individuals under the age of 18.

In light of the above, the Authority contested Luka for the possible violation of Article 5, paragraph 1,

letter c), 6; 7; 8; 24 and 25, paragraph 1 of the Regulation for the failure to establish suitable systems to verify the age of individuals as of February 2, 2023.

****4. EXISTENCE OF EURO-UNITARY JURISDICTION AND COMPETENCE OF THE GUARANTOR****

Preliminarily, the Authority finds it appropriate to address the issues related to the applicability of European data protection legislation to the service offered by Luka and the competence of the Guarantor, also considering the exceptions raised by the Company in its response dated May 8, 2023, to the request for information transmitted by the Authority.

Article 3 of the Regulation governs the territorial scope of application of the legislation, establishing different criteria depending on whether the data controller is established in the territory of the European Union or not.

In the first case (Article 3, paragraph 1, so-called establishment criterion), the Regulation applies regardless of whether the processing is carried out in the Union, and competence is identified in accordance with the mechanism of the so-called one-stop-shop, pursuant to Article 56 of the Regulation itself.

In the second hypothesis (art. 3, par. 2, so-called targeting criterion), the Regulation applies to the processing of personal data of data subjects located in the Union when the processing activities concern: i) the offering of goods or the provision of services to data subjects in the Union (art. 3, par. 2, lett. a), of the Regulation); ii) the monitoring of the behavior of data subjects located in the Union to the extent that such behavior takes place within the Union itself (art. 3, par. 2, lett. b), of the Regulation).

The Company stated, in the aforementioned note, that it has a single establishment in the European Union in the Netherlands, reporting that it has “a group of employees located in the Netherlands, including several decision-makers involved in the cross-border processing of data for the development of LLMs and the product” and that “the employees of the Company located in the Netherlands are involved in decisions regarding the processing of personal data by the Company and the operation of LLMs globally, including decisions regarding the minimum proportion of users located in Italy.”

The existence of a Dutch establishment in the European Union would imply the application of the one-stop-shop mechanism and the competence, as the lead supervisory authority and in cooperation with the concerned authorities, of the Dutch data protection authority.

However, this assertion finds no support in the documents. In fact, neither in the privacy policy published on the Replika website as of February 2, 2023 (version updated on July 5, 2022) nor in subsequent versions of the same (including the current version updated on February 23, 2024) is there any mention of an establishment of the Company in the Netherlands; similarly, no mention can be found in the terms of service (neither in the version updated on September 14, 2022 nor in the current version, updated on February 7, 2023), where, rather, it states that Luka is “a software company who designed and built Replika, incorporated in Delaware, and operating in San Francisco, CA.”

Moreover, the statements in the note of May 8, 2023, are absolutely generic as they do not even indicate the name and corporate identity of the company that would be established in the European Union (thus making any verification through mutual assistance with the Dutch supervisory authority pursuant to art. 61 of the Regulation impossible) and are not supported by any documentary evidence (e.g., the articles of incorporation of the Dutch company or a chamber of commerce registration).

At this stage, therefore, the Authority believes that no element has been provided that can validly demonstrate the existence of an establishment of the Company in the European Union, with the consequent applicability of the establishment criterion under art. 3, par. 1, of the Regulation and the one-stop-shop mechanism in favor of the Dutch data protection authority.

In this specific case, the existence of EU jurisdiction and the competence of the Authority must be assessed based on the targeting criterion set forth in art. 3, par. 2, of the Regulation: specifically, it is necessary to preliminarily evaluate whether the Replika service can be considered offered to data subjects located in the European Union for the purposes of the applicability of letter a) of the aforementioned art. 3 of the Regulation.

In this regard, reference is made to the “Guidelines 3/2018 on territorial scope,” adopted by the European Data Protection Board (EDPB) on November 12, 2019, which provide that the “data controller... must demonstrate its intention to offer goods or services to a data subject located in the Union” (see par. 2 (a) of the cited Guidelines) and the jurisprudence of the Court of Justice of the European Union (judgment Pammer/Reederei Karl Schlüter GmbH & Co and Hotel Alpenhof/Heller - joined cases C-585/08 and C-144/09), which has indicated certain factors in the presence of which it may be deemed that a commercial activity carried out by a subject is directed towards a Member State, including the circumstance that the European Union is mentioned in relation to the good or service offered, the international nature of the activity, or the initiation of advertising and marketing campaigns aimed at the public of a country in the EU.

In this specific case, the evidence that the Replika service was offered to data subjects located in the European Union and, in particular, in Italy as of February 2, 2023, emerges “per tabulas” from the first response of the Company to the order for provisional limitation contained in the urgent measure of the Authority no. 39/2023, where it states (see note of March 3, 2023, p. 1) that “the Company has promptly complied with the request for temporary limitation of processing for users established in Italian territory, promptly disabling access to both the app and the website of the service from Italy.”

Having demonstrated in the ways and terms mentioned above the territorial applicability of the Regulation and the competence of the Authority, the following observations are made. The processing of personal data carried out by

Luka can be classified as cross-border processing of personal data pursuant to Article 4, paragraph 1, number 23 of the Regulation, as it is capable of affecting data subjects in more than one Member State. For this type of processing, where the data controller has identified a single or main establishment in the European Union, as previously illustrated, the cooperation mechanism described in Articles 60 et seq. of the Regulation applies, and the competence to perform the tasks and exercise the powers provided for in Articles 57 and 58 of the Regulation is vested, pursuant to Article 56, paragraph 1, of the Regulation, in the lead supervisory authority, namely the supervisory authority of the Member State where the single or main establishment is located. Conversely, where, as in this case, there is no establishment of the data controller in the European territory, the latter must “interface with the supervisory authorities of each Member State in which it operates through the designated representative” (see paragraph 3.3. of the “Guidelines on the Lead Supervisory Authority” adopted by the Article 29 Working Party on December 13, 2016, revised on April 5, 2017, and endorsed by the EDPB on May 25, 2018). In fact, where a controller does not have an establishment in the European Union (or rather in the EEA), the special rule set out in Article 56 does not apply in favor of the general rule provided for in Article 55, paragraph 1, of the Regulation, according to which “each Supervisory Authority is competent to perform the tasks assigned to it and to exercise the powers conferred on it under the (...) Regulation within the territory of its respective Member State.” In the case at hand, as mentioned, Luka is a company based in the United States of America that has not demonstrated having an establishment in the territory of the European Union. Therefore, the Italian data protection authority is competent to assess, with regard to its territory, the compliance with the Regulation of the personal data processing carried out by the Company and to exercise the powers granted to it by Article 58 of the Regulation.

5. ESTABLISHED VIOLATIONS

5.1 ARTICLES 5, PARAGRAPH 1, LETTER A) AND 6 OF THE REGULATION

The Office has contested to Luka the violation of Articles 5, paragraph 1, letter a) and 6 of the Regulation for failing to identify, as of February 2, 2023, the legal bases for the various processing operations carried out through the Replika service, a service offered and available to the public in Italy as of that date. Article 5, paragraph 1, of the Regulation prescribes that “personal data shall be: a) processed lawfully, fairly and in a transparent manner in relation to the data subject (‘lawfulness, fairness and transparency’); b) collected for specified, legitimate purposes and not further processed in a manner that is incompatible with those purposes; further processing of personal data for archiving purposes in the public interest, scientific or historical research or statistical purposes shall not be

considered incompatible with the initial purposes in accordance with Article 89, paragraph 1 ('purpose limitation'); c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimization'); d) accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate are erased or rectified without delay ('accuracy'); e) kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; personal data may be stored for longer periods insofar as the personal data will be processed solely for archiving purposes in the public interest, scientific or historical research or statistical purposes, in accordance with Article 89, paragraph 1, subject to the implementation of appropriate technical and organizational measures required by this Regulation to safeguard the rights and freedoms of the data subject ('storage limitation'); f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality')." Paragraph 2 of the same provision states that "the controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 ('accountability')." Recital 39 clarifies that "Any processing of personal data should be lawful and fair. The ways in which personal data are collected, used, consulted or otherwise processed should be transparent to individuals, as well as the extent to which personal data are or will be processed. The principle of transparency requires that information and communications relating to the processing of such personal data be easily accessible and understandable, and that clear and plain language be used. This principle relates, in particular, to the information provided to data subjects about the identity of the data controller and the purposes of the processing, and further information to ensure fair and transparent processing with regard to the data subjects and their rights."

****Rights to Obtain Confirmation and Communication of the Processing of Personal Data Concerning Them****

Article 6 of the Regulation prescribes the conditions for the lawfulness of processing by listing the six possible legal bases (consent, contract, legal obligation, vital interest, public interest, legitimate interest) on which the data controller must rely in order to lawfully process the personal data necessary for the performance of its activities. The legal basis, as clarified by the EDPB, "must be identified prior to the implementation of the processing and must be specified in the information provided to the data subjects in accordance with Articles 13 and 14. (See the Guidelines 2/2019 on the processing of personal data pursuant to Article 6, paragraph 1, letter b), of the General Data Protection Regulation in the context of providing online services to data subjects)."

The Company did not submit any defensive writings or documents, pursuant to Article 166, paragraph 5 of the Code, following the notification of the notice of contestation and the initiation of the procedure by the Office and therefore did not provide any counterarguments regarding the alleged violation related to the failure to indicate the legal basis for each of the processing activities carried out by Luka in the context of the Replika service.

In this specific case, from the investigative documents, particularly from the text of the privacy policy published as of the date of the adoption of the urgent measure by the Guarantor, updated as of July 5, 2022, it clearly emerges that the Company did not granularly identify the legal basis underlying the various processing operations carried out by the Company in the context of the Replika service, including that for the processing of data used for the development of the LLM model.

The only references in the introductory part of the text in question are as follows: "We care about the protection and confidentiality of your data. We therefore only process your data to the extent that:

- It is necessary to provide the Replika services you are requesting,
- You have given your consent to the processing, or
- We are otherwise authorized to do so under the data protection laws."

The legal bases of the execution of a contract (Article 6, paragraph 1, letter b), of the Regulation), the consent of the data subjects (Article 6, paragraph 1, letter a), of the Regulation), and a legal authorization (where, moreover, the Regulation provides among the legal bases a legal obligation, not

a mere authorization), are implicitly and generically referenced, without referring to specific processing operations (so-called principle of granularity), resulting in the impossibility of identifying and assessing their suitability.

Finally, neither the privacy policy nor the documentation in the records contain references to the legal basis underlying the processing of personal data aimed at the development of the LLM model that powered the chatbot as of February 2, 2023. Specifically, the responses provided by Luka, although relevant, are not decisive. In particular, the DPIA and the privacy policy produced on May 8, 2023, do not allow for overcoming the objections raised by the Authority during the contestation regarding the principle of lawfulness and the legal basis for processing, respectively governed by Articles 5, paragraph 1, letter a) and 6 of the Regulation, as follows:

- the privacy policy, even in the subsequent version updated on March 22, 2023, in the table referred to in paragraph 2.A, does not expressly mention the purpose of “Model Development” nor the related legal basis;
- the DPIA, while distinguishing the two purposes of processing related to “Chatbot Interaction” and “Model Development” (paragraph I) and analyzing the respective legal bases (paragraph II), does not present a certain date, for which it does not prove that the identification of the aforementioned conditions of lawfulness referred to in Article 6 of the Regulation occurred prior to February 2, 2023. Moreover, the DPIA states legitimate interest as the legal basis for processing for the purpose of “Model Development” without indicating any arguments related to the so-called “triple test” underlying the legitimate interest assessment. Finally, it is highlighted that the DPIA, while being an excellent tool for accountability, does not constitute the chosen venue by the legislator to provide data subjects with information regarding processing activities, information that must be provided through the privacy policy.

With reference to Article 5, paragraph 1, letter a), of the Regulation, the principle expressed by the EDPB in binding decision no. 1/2021 regarding transparency is recalled here, but it can also be applied with reference to lawfulness, according to which the principles of Article 5 of the Regulation must be considered as a general concept that is then concretely implemented in various provisions and specific obligations (in the case of lawfulness, in Articles 6, 7, 8, 9, and 10 of the Regulation).

Thus, according to the EDPB, it is necessary to distinguish the specific obligations arising from a principle (in this case, Article 6 of the Regulation) from the principle itself expressed in Article 5 of the Regulation, as the latter cannot be confined to the specific obligation, although the latter is a concretization of the former. The principle of lawfulness, in fact, is a comprehensive principle that reinforces other principles (e.g., fairness, accountability). The confirmation of this reconstruction is provided by the fact that Article 83, paragraph 5, of the Regulation provides for the possibility of sanctioning the violation of lawfulness obligations independently of the violation of the principle itself. In this case, the Authority believes that a violation of the principle of lawfulness referred to in Article 5, paragraph 1, letter a) of the Regulation can also be identified, taking into account the severity (failure to clearly and granularly identify the legal bases underlying the various processing operations) of the nature (it is an essential element of the processing) and the impact (it is a new type of processing related to an innovative technology such as generative artificial intelligence) of the specific violation of the obligation referred to in Article 6 of the Regulation.

For the reasons stated above, the Authority believes that Luka did not identify, as of February 2, 2023, the legal bases for the various processing operations carried out through the Replika service, offered and available to the public in Italy on that date, in violation of Articles 5, paragraph 1, letter a) and 6 of the Regulation.

Regarding the analysis and assessment of the merits concerning the legal bases referred to in Article 6, paragraph 1, letter b) and letter f), of the Regulation allegedly established as the basis for the use of the chatbot and the post-training of the LLM model underlying the Replika service, as well as, in general, the legal bases related to the entire lifecycle of the generative artificial intelligence system implemented by the Company, the Authority reserves the right to open a separate and autonomous investigation.

5.2 ARTICLES 5, PARAGRAPH 1, LETTER A), 12 AND 13 OF THE REGULATION

The Office has contested Luka for the violation of Articles 5, paragraph 1, letter a), 12, and 13 of the Regulation for having provided, as of February 2, 2023, a privacy policy related to the Replika service with content that does not comply with the obligations and general principles regarding transparency provided for by the legislation.

Article 5, paragraph 1, letter a), of the Regulation prescribes that personal data must be processed lawfully, fairly, and transparently concerning the data subject (principle of lawfulness, fairness, and transparency). Article 12 of the Regulation sets out rules regarding transparency and the exercise of rights, while Article 13 introduces specific indications regarding the information that the data controller is required to provide when personal data is collected from the data subject.

Regarding transparency, Recital 58 of the Regulation provides that information intended for the public or the data subject must be concise, easily accessible, and easy to understand, that simple and clear language should be used, and, with reference to the specific protection that must be afforded to minors, it states that “when the processing of data concerns them, any information and communication should use simple and clear language that a minor can easily understand.”

On the topic of transparency, the indications of the Committee are also relevant, particularly the guidelines 2/2019 on the processing of personal data under Article 6, paragraph 1, letter b) of the General Data Protection Regulation in the context of providing online services to data subjects, where it is stated that the legal basis for processing, in addition to being identified before the implementation of the processing, “must be specified in the information provided to data subjects in accordance with Articles 13 and 14”; furthermore, the guidelines no. 1/2022 of the Committee on access prescribe, in paragraph 142, that “a data controller offering a service in a particular country should also respond in a language understood by the data subjects of that country.”

Finally, the guidelines adopted by the Article 29 Working Party on April 11, 2018, clarified that “in the regulation, the concept of transparency is not legalistic but rather user-centered and is concretized in various articles containing specific obligations imposed on data controllers and processors. The concrete obligations (of information) are indicated in Articles 12-14 of the regulation. (...) The transparency obligations imposed by the regulation apply regardless of the legal basis for processing and throughout the entire lifecycle of the processing. This is clear from Article 12, which establishes that transparency applies in the following phases of the data processing cycle: i) before or at the beginning of the data processing cycle, that is, when personal data is collected from the data subject or obtained in another way; ii) throughout the entire lifecycle of the treatment, or in communication with the data subjects regarding their rights; ii) at specific moments when the processing is ongoing, for example when a data breach occurs or in the event of a significant change in the processing.”

The Company did not submit any defensive writings or documents, pursuant to Article 166, paragraph 5 of the Code, in response to the notice of contestation and initiation of proceedings by the Office and therefore did not provide any counterarguments regarding the alleged violation concerning the obligations and general principles of transparency provided for by the regulations.

The investigation by the Office, as previously specified, focused on the privacy policy adopted and published by Luka as of February 2, 2023, namely the version updated as of July 5, 2022.

From the investigative documents, it emerges that, from a formal point of view, as of February 2, 2023, the privacy policy was available only in English, disregarding the language of the country in which the service was offered, specifically the Italian language.

From a substantive perspective, it is noted that as of February 2, 2023, the privacy policy did not comply with the principles of fairness and transparency as it was incomplete and incorrect.

In particular, from the standpoint of the completeness of the information provided to the data subjects, it was found that the privacy policy:

- did not granularly indicate the legal basis for each of the processing activities carried out, nor the type of data processed;
- did not specify the purposes of the two distinct types of processing activities, namely the processing of data through "Chatbot Interaction," aimed at allowing users to register for the service and interact with the platform, and the processing of data within the "Model Development," aimed at improving the security and performance of the Large Language Model (LLM) underlying the service offered;
- did not clarify that the service was offered exclusively to individuals over the age of 18, while inviting minors under the age of 13 not to use the service. In particular, paragraph 8 of the aforementioned privacy policy stated: "We do not knowingly collect Personal Data from children under the age of 13. If you are under the age of 13, please do not submit any Personal Data through the Services. We encourage parents and legal guardians to monitor their children's Internet usage and to help enforce our Privacy Policy by instructing their children never to provide Personal Data on the Services without their permission. If you have reason to believe that a child under the age of 13 has provided Personal Data to us through the Services, please contact us, and we will endeavor to delete that information from our databases." Such information, while making clear that the service was not offered to individuals under 13 years old ("If you are under the age of 13, please do not submit any Personal Data through the Service"), did not clarify that the chatbot was reserved only for adults, as users aged between 13 and 18 were also excluded. This latter circumstance was clarified by the Company only at a later stage;

- did not provide any specific indication regarding the retention period of personal data or the criteria used to determine such period;

- did not clarify whether there was a transfer of personal data outside the EEA and, if so, what the legal basis for the processing was and what adequacy guarantees were adopted pursuant to Chapter V of the Regulation. More specifically, the information provided by the Company (notably in the part of the privacy policy where it stated: "By using our services or providing us with any information, you consent to this transfer, processing, and storage of your information in the U.S.A., a jurisdiction in which the privacy laws may not be as comprehensive as those in the country where you reside or are a citizen") was likely to create a misleading belief in the data subject regarding the transfer of their personal data to the USA. The absence of a data transfer to third countries was confirmed by the Company itself in the note dated May 8, 2023 (prot. 74173/23) regarding the applicability of the establishment criterion within the European Union. Therefore, it is noted that the presence of misleading information was confirmed by the statements of the data controller;

- in section 6 "Your data protection rights," while not expressly referencing Article 22 of the Regulation, provided specific information regarding this right, leading the user to the unfounded belief that their personal data was subject to automated decision-making. The absence of automated processing pursuant to Article 22 of the Regulation was confirmed by the data controller in the response note (prot. 74173/23), where it has

****Claiming that "although the chatbot relies on automated processes to generate responses, the Services do not make decisions based on profiling that have legal effects or similar significance pursuant to Article 22 of the Regulation." Therefore, even in this case, it is noted that the presence of misleading information has been confirmed by the statements of the data controller.****

With reference to Article 5, paragraph 1, letter a) of the Regulation, the same binding decision of the EDPB cited in the previous paragraph (binding decision no. 1/2021) is recalled, according to which transparency must be considered a general concept that finds concrete implementation in various provisions and specific obligations (for example, Articles 12, 13, 14, 25, and 35). It is therefore necessary to distinguish the specific obligations arising from the principle of transparency (as per Articles 12-14 of the Regulation) from the principle expressed in Article 5 of the Regulation, as although such obligations are a concretization of the general principle, the latter has a broader scope.

The principle of transparency, in fact, is a comprehensive principle that reinforces other principles (e.g., fairness, accountability). The confirmation of this reconstruction is given by the fact that Article 83, paragraph 5, of the Regulation provides for the possibility of sanctioning the violation of

transparency obligations independently of the violation of the principle itself. In other words, the transparency obligations do not define the entire scope of the principle of transparency; it follows that the violation of the transparency obligations provided for in Articles 12-14 of the Regulation may also constitute a violation of the principle of transparency only if characterized by elements of seriousness and systematicity.

In this specific case, the Authority believes that a violation of the principle of transparency referred to in Article 5, paragraph 1, letter a) of the Regulation can also be identified, considering the seriousness (absence of information to the data subjects regarding the legal bases underlying the various processing operations of their personal data) of the nature (lack of clear information regarding the essential elements of processing such as legal basis, purpose, retention principle, extra-EU transfer) and the impact (this is a type of processing new connected to an innovative technology such as generative artificial intelligence) of the specific violations of the obligations referred to in Articles 12 and 13 of the Regulation.

For the reasons stated above, the Authority believes that Luka violated, as of February 2, 2023, Articles 5, paragraph 1, letter a), 12, and 13 of the Regulation.

For completeness, it is noted that further technical investigations revealed that the data controller has again updated the privacy policy related to the Replika service on February 23, 2024. In this version, some of the imprecise and incorrect information mentioned above have been modified. Specifically, the privacy policy, in effect at the date of adoption of this provision, granularly reports the legal basis related to each of the processing activities carried out by the data controller and the type of data processed; it expressly clarifies that the service is offered exclusively to adults and does not present any reference, even implicit, to automated decisions referred to in Article 22 of the Regulation. Nevertheless, the information provided pursuant to Articles 12 and 13 of the Regulation continues to be available only in English, does not provide specific references regarding the retention period of personal data or the criteria used to determine such period, and is potentially capable of misleading the data subject regarding the transfer of their personal data to the USA.

****5.3 ARTICLES 5, PAR. 1, LETTER C), 6, 7, 8, 24 AND 25, PAR. 1, OF THE REGULATION****

The Office has contested Luka for the violation of Articles 5, paragraph 1, letter c); 6; 7; 8; 24 and 25, paragraph 1 of the Regulation for failing to establish systems capable of verifying the age of subjects as of February 2, 2023.

Pursuant to Article 5, paragraph 1, letter c), of the Regulation, "Personal data shall be adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed."

Pursuant to Article 24, paragraph 1, of the Regulation, "Taking into account the nature, scope, context and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure, and to be able to demonstrate, that the processing is performed in accordance with this Regulation. These measures shall be reviewed and updated where necessary."

Pursuant to Article 25, paragraph 1, of the Regulation, the data controller must adopt such measures "taking into account the state of the art and the costs of implementation, as well as the nature, scope, context and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons arising from the processing, both at the time of determining the...

treatment both at the time of the treatment itself." In the guidelines no. 4/2019 on Article 25 of the Regulation, the EDPB clarified that "the core of the provision is to ensure adequate and effective data protection from the design stage and a protection by default, which means that data controllers should be able to demonstrate that they incorporate into the processing the measures and guarantees necessary to ensure the effectiveness of data protection principles, and the rights and freedoms of data subjects" and invited controllers to take into account, in the design and setting of processing from a privacy-oriented perspective, the obligations to provide specific protection for minors and other

groups of vulnerable subjects.

In the same guidelines, the EDPB also emphasized that “In line with Article 25, paragraph 1, the controller implements appropriate technical and organizational measures that are designed to implement the principles of data protection and integrates into the processing the necessary guarantees to comply with the requirements and protect the rights and freedoms of data subjects. Both the appropriate measures and the necessary guarantees aim to pursue the same purpose of protecting the rights of data subjects and ensuring that the protection of their personal data is integrated into the processing. The expressions technical and organizational measures and necessary guarantees can be understood broadly as any method or means that a controller can employ in the processing. By the term appropriate, it is meant that the measures and necessary guarantees must be suitable to achieve the intended purpose, that is, they must effectively implement the principles of data protection.”

The Company did not submit any defensive writings or documents, pursuant to Article 166, paragraph 5 of the Code, in response to the notice of contestation and initiation of proceedings by the Office and therefore did not provide any counterarguments regarding the alleged violation concerning the failure to establish systems capable of verifying the age of the subjects.

In light of the aforementioned norms and orientation, the Authority observes that the controller has the obligation to implement appropriate technical and organizational measures to ensure and demonstrate that the processing is carried out in accordance with the Regulation and to process only data that is adequate, relevant, and limited to what is necessary for the purposes of the processing itself.

However, the investigation revealed the Company's failure to establish measures aimed at ensuring specific protection for the personal data processed within the Replika service concerning minors under 18 years of age. In fact, the absence of age verification procedures for users intending to access the service, as well as mechanisms for prohibition or blocking in the face of statements from the user that made their minor age clear, highlighted that the controller did not assess, ex ante, the risks that the registration and use of the service by minors under 18 years could entail, with the consequence that, on the one hand, it did not adopt any measures to counter such risks, minimize them, or contain them, and on the other hand, it processed data exceeding what was necessary to meet the purposes of the processing (namely, the offering of the service to adult users).

From the investigation, it emerged that as of February 2, 2023, the Company did not foresee any mechanism for verifying the age of users either at the time of registration for the Replika service or during its use, even though it excluded minors among potential users.

In particular, the absence of the following was noted:

- A user age verification procedure (the system only required name, email, and gender) with the consequent risk of presenting inappropriate responses to minors concerning their level of development and self-awareness, including sexually explicit content;
- Mechanisms for prohibition or blocking even in the face of user statements that made their minor age evident, as well as the presentation of responses by the chatbot that were clearly in contrast with the protections that should be ensured for minors and, more generally, for all more vulnerable subjects.

Until February 2, 2023, therefore, the Company did not adopt any technical and organizational measures aimed at ensuring compliance with the general principles of the Regulation and the protection of the rights and freedoms of minors, thereby exposing minors to significant risks to their person that the relevant legislation aims to limit, including inappropriate responses concerning their level of psychophysical development and self-awareness.

Luka adopted age verification mechanisms only following the request of the Authority made within the framework of the provisional limitation measure, adopted urgently on February 2, 2023. In particular, during the discussions that followed the adoption of the aforementioned measure and with specific reference to the age gate profile, the Company represented that it had implemented on all registration pages for the Replika service...

****Services an age gate that limits access to users who are 18 years old and includes a "cooling-off period" aimed at preventing individuals who have failed to access the service by entering real personal data from immediately entering a different date of birth. The Company has also represented that it has planned the development of a process to use language analysis to identify and prevent the use of the Services by individuals under the age of 18. Before the intervention of the Authority, therefore, all users, including minors, could register for the Replika service and use it without being asked to undergo any age verification. As clarified in the contestation, in the opinion of the Authority, the absence of a common standard suitable to ensure, in a certain and absolute manner, the effectiveness of a user age verification model and the ongoing discussion at the European level regarding this matter cannot be considered sufficient reasons to exclude compliance with the obligations to which the data controller is subject, specifically the obligation to verify the actual contractual capacity of the user for the validity of the contract. From the above, it emerges that, as of February 2, 2023, the Company has neither implemented, pursuant to Article 24 of the Regulation, measures aimed at ensuring that the processing of data at the time of registration for the Replika service was compliant with Articles 5, paragraph 1, letter c), 24, 25 of the Regulation, in particular that it had adopted technical and organizational measures "aimed at effectively implementing data protection principles, such as minimization, and integrating the necessary safeguards into the processing to meet the requirements of this Regulation and protect the rights of the data subjects," resulting in the processing of excessive data, or rather unnecessary data, with respect to the purposes of a service that, according to the statements of the data controller as well as the documentation on file, was offered only to users over the age of 18. With specific reference to the violation of Article 5, paragraph 1, letter c), of the Regulation, it is noted that, in this case, the adoption of adequate technical and organizational measures, from the design stage, aimed at "effectively implementing data protection principles, such as minimization," besides being a constitutive element of Article 25, paragraph 1, of the Regulation, also constitutes a *quid pluris* suitable to consider the violation of the principle of minimization integrated, in line with what is clarified by Recital 78 of the Regulation. Specifically, the failure by the Company to adopt measures suitable to safeguard access and use of the Replika service has resulted not only in Luka systematically processing personal data beyond what was actually necessary to achieve the purpose of the processing (namely, to offer the service to adult users), but also in such processing concerning data related to vulnerable subjects (minors, potentially under the age of 13) who, due to this deficiency and given the innovative technology underlying the service and the highly sensitive nature of the conversations provided by the chatbot, have been exposed to a particularly high risk. News reports that led to the initiation of the Authority's investigation, along with concrete cases of self-harm linked to the use of the chatbot reported by foreign press and brought to the attention of the judicial authority, are elements that support the Office's contestation and, based on the principles expressed by the repeatedly referenced binding decision of the EDPB No. 1/2021, require the assessment of the severity and impact of the violations, leading to the conclusion that both the violation of the principle referred to in Article 5, paragraph 1, of the Regulation and the specific violation of the obligation under Articles 24 and 25, paragraph 1, of the Regulation are integrated. The Authority, on the contrary, does not believe that there are sufficient elements to declare the violations contested under Article 166, paragraph 5, of the Code, regarding consent, specifically the positive act expressed by the minor within digital services, as referred to in Articles 6, 7, 8 of the Regulation. In particular, it is noted that during the investigation it emerged that, contrary to what was erroneously indicated in the privacy policy dated February 2, 2023 (see § 5.2) - the Replika service was not - and is not - offered to minors, it follows that the data controller was not required to comply with the obligation to identify a legal basis for treatments that were presumed not to be carried out. For the reasons stated above, the Authority believes that Luka violated, as of February 2, 2023, Articles 5, paragraph 1, letter c) and 24 and 25, paragraph 1, of the Regulation. For completeness, it is noted that, as of the date of adoption of this provision, further technical checks have revealed that the age verification system currently implemented by the data controller continues to be deficient in several respects; in particular, it has been established that:**

- after the creation of the user profile, it is possible to modify the date of birth in the "My Profile" section without any verification by the data controller, resulting in a minor who has registered for the service

indicating a false age being able to promptly change it to the correct one without any consequences, continuing to access the service;

- the cooling-off period (of 24 hours) does not apply where the profile is created through incognito browsing; in fact, it appears that once the first age check fails, it is possible to successfully complete the registration for the service by changing the email address entered to a new one (including non-existent and non-functional email addresses);
- no linguistic analysis mechanisms have been put in place that require users to reconfirm their age through the age gate process when they identify themselves as under 18 years old, with the sole exception of cases where the user provides specific inputs (e.g., unequivocally declaring themselves to be under 18 years old). In such cases, the application responds by asking for confirmation of the user's age.

Additionally, during the technical checks, it was found that users are offered the possibility to mark certain conversations as inappropriate; however, it is not possible to ascertain the consequences of such reporting.

6. CONCLUSIONS

In light of the evaluations expressed above, it is confirmed that most of the violations contested by the Office, notified with the initiation of the proceedings, exist as indicated below, and the unlawfulness of the processing of personal data carried out by the Company is declared, in violation of Articles 5, paragraph 1, letter a) (with reference to both the principle of lawfulness and transparency) and letter c), 6, 12, 13, 24, and 25, paragraph 1, of the Regulation.

The ascertainment of the violation of the aforementioned provisions of the Regulation necessitates the subsequent adoption of corrective measures pursuant to Article 58, paragraph 2, of the Regulation, specifically the order to bring into compliance under Article 58, paragraph 2, letter d) of the Regulation, and also makes applicable, pursuant to Articles 58, paragraph 2, letter i), of the Regulation, the administrative sanction provided for by Article 83, paragraphs 3 and 5, of the same Regulation.

Furthermore, considering the particular sensitivity of the data processed, it is also deemed necessary to apply the ancillary sanction of publication on the Garante's website of this provision, as provided for by Article 166, paragraph 7 of the Code and Article 16 of the Garante Regulation No. 1/2019.

The Authority reserves the right, as specified above, to examine and verify in a separate proceeding the aspects concerning the lawfulness of the processing carried out by the Company, specifically regarding the legal bases for the processing of personal data related to the entire lifecycle of the generative artificial intelligence system underlying the Replika service.

7. CORRECTIVE MEASURES UNDER ARTICLE 58, PARAGRAPH 2, LETTER D) OF THE REGULATION

Article 58, paragraph 2, of the Regulation provides the Garante with a series of corrective powers, of a prescriptive and sanctioning nature, to be exercised in the event that unlawful processing of personal data is ascertained.

Among these powers, Article 58, paragraph 2, letter d), of the Regulation provides the power to “instruct the data controller ... to bring the processing into compliance with the provisions of this regulation, if necessary, in a specific manner and within a specific timeframe.”

From what has been noted and deemed in the preceding paragraphs, it has emerged that Luka violated, as of February 2, 2023, Articles 5, paragraph 1, letter a) (with reference to both the principle of lawfulness and the principle of transparency) and letter c), 6, 12 and 13, Articles 24 and 25, paragraph 1 of the Regulation, but that, following the urgent intervention of the Authority, it adopted some measures to remedy the identified issues and subsequently adopted further measures regarding the violations contested in the initiation of the proceedings, which ensure compliance of the processing with the data protection legislation.

Specifically, Luka has remedied the violation of Articles 5, paragraph 1, letter a) and 6 of the Regulation by modifying the privacy policy (see latest version dated February 23, 2024), specifying in detail the legal bases for the various processing operations carried out through the Replika service. In light of the modification of the privacy policy as described above, it is deemed that, at this time, the conditions for the adoption of further corrective measures under Article 58, paragraph 2, of the Regulation do not exist.

On the other hand, with regard to the violation of Articles 5, paragraph 1, letter a), 12 and 13 of the Regulation...

Regulation regarding informational obligations and the violation of Articles 24 and 25, paragraph 1 and 5, paragraph 1, letter c), of the Regulation, concerning the age verification system, there remain aspects of non-compliance with the Regulation that are deemed to require specific prescriptions.

In particular, with reference to the informational obligations, the Authority has ascertained that, to date, Luka's privacy policy (latest version dated February 23, 2024) continues to be non-compliant with the regulations on personal data protection to the extent that i) it is available only in English, ii) it does not precisely indicate the retention periods for personal data or the criteria used to determine such periods, iii) it is likely to generate a false belief among data subjects regarding the transfer of their personal data to the USA.

Therefore, pursuant to Article 58, paragraph 2, letter d), of the Regulation, the data controller is ordered to align the privacy policy with Articles 5, paragraph 1, letter a), 12, and 13 of the Regulation, remedying the aforementioned gaps.

Furthermore, with reference to the age verification system, the Authority has determined that, as of the date of adoption of this measure, the age verification system employed by the data controller is not compliant with the principle of data minimization and the principles of privacy by design and by default, given that:

- after the creation of the profile, the user can modify the date of birth in the "My Profile" section without any verification by the data controller. This means that a minor who has registered for the service indicating a false age could promptly change it to the correct one without any consequences and continue to access the service;
- the 24-hour cooling-off period does not apply when the user creates the profile while browsing in incognito mode; in fact, it appears that once the first age check fails, the user can successfully complete the registration for the service by changing the email address entered to a new one (including non-existent and non-functional email addresses);
- the data controller has not implemented linguistic analysis mechanisms that require users to reconfirm their age through the age gate process in the presence of clear signs identifying a user under 18 years of age, with the sole exception of cases where the user provides specific inputs (e.g., unequivocally declaring to be under 18 years old). Only in such cases does the application respond by asking for confirmation of age.

The Authority has, however, positively noted the implementation by Luka of a feature that allows users to mark certain conversations as inappropriate, although it has not been possible to detect the effect of such reporting.

That said, pursuant to Article 58, paragraph 2, letter d) of the Regulation, the data controller is ordered to align the age verification system with Articles 5, paragraph 1, letter c), 24, and 25, paragraph 1 of the Regulation, remedying the aforementioned gaps.

8. ORDER FOR THE IMPOSITION OF ADMINISTRATIVE FINANCIAL SANCTIONS AND ACCESSORY SANCTIONS

The Authority, pursuant to Article 58, paragraph 2, letter i), and Article 83 of the Regulation as well as Article 166 of the Code, has the power to impose an administrative financial sanction pursuant to Article 83, in addition to or in place of the other corrective measures provided for in the same paragraph.

In determining the sanction, the Authority takes into account the principles and interpretation provided by the EDPB in Guidelines 4/2022 on the calculation of administrative financial sanctions pursuant to the GDPR, version 2.1, adopted on May 24, 2023.

Based on the arguments presented above, the Authority has established the violation of the following provisions of the Regulation: Articles 5, paragraph 1, letter a) and 6; Articles 5, paragraph 1, letter a), 12, and 13; Articles 5, paragraph 1, letter c), 24, and 25, paragraph 1, of the Regulation.

In this specific case, it should first be noted that the Company has engaged in a series of conduct that has constituted multiple violations, as specifically outlined and justified in the previous paragraphs. The violations related to the legal basis (Articles 5, paragraph 2 and 6 of the Regulation), transparency (Articles 5, paragraph 1, letter a), 12, and 13), and the age gate (Articles 24 and 25, paragraph 1) can be attributed, under the principle of unity of action, to Article 83, paragraph 3, of the Regulation, according to which, in the presence of multiple violations of the Regulation related to the same processing or connected processes, the total amount of the administrative financial sanction cannot exceed the amount provided for the most serious violation.

In particular, with reference to these violations, a case of connected processing can be configured, as defined in paragraph 28 of the aforementioned guidelines.

conduct (a unitary conduct consists of multiple actions that are carried out based on a unitary will and are so closely correlated in time, space, and context that they can be considered, from an objective point of view, as a single coherent conduct). The most serious violation compared to those mentioned above must be found in the violation of transparency obligations since both Article 5, paragraph 1, letter a) (principle of transparency) and Articles 12 and 13 (rights of the data subjects) are sanctioned under Article 83, paragraph 5, which sets the maximum penalty at 20 million euros or, for companies, 4% of the annual global turnover of the previous financial year if higher.

Pursuant to Article 83, paragraph 1 of the Regulation, the administrative sanction must be effective, proportionate, and dissuasive in relation to the individual case. In the aforementioned guidelines, the EDPB clarified that the calculation of administrative monetary penalties should start from a harmonized starting point, which constitutes the initial basis for the further calculation of the amount of the sanction, taking into account and weighing all the circumstances of the case (see paragraph 46). The harmonized starting point must consider three factors: 1) nature of the violation pursuant to Article 83, paragraphs 4 to 6, of the Regulation; 2) severity of the violation; 3) turnover of the company (see paragraph 48).

Starting from the first aspect, in this case, there are two violations, in abstract, of a more serious nature (Article 83, paragraph 5, of the Regulation) and one less serious violation (Article 83, paragraph 4, of the Regulation). The first two refer to the violation of the legal basis and transparency, while the third concerns the violation of Article 25 of the Regulation.

Regarding the concrete severity, the elements to be considered are: a) nature, severity, and duration of the violation (Article 83, paragraph 2, letter a), of the Regulation); b) intentional or negligent nature of the violation (Article 83, paragraph 2, letter b), of the Regulation); c) categories of personal data involved in the violation (Article 83, paragraph 2, letter g), of the Regulation).

In the case at hand, with reference to the three violations linked by the principle of unity of action (legal basis, transparency, and data protection by design and by default), the severity of the violations must be considered high since: i) the nature of the violations pertains to two fundamental principles (accountability and transparency), specifically, on one hand, the inability of the data controller to demonstrate that they had identified the legal bases for processing before the processing began and, on the other hand, the failure to provide adequate information to the data subject, particularly regarding the purposes of the two distinct types of processing ("Chatbot Interaction" and "Model Development," and the involvement in the processing activities of data, such as that of minors, beyond what is necessary to fulfill the purpose of providing the service; ii) the nature of the processing involves significantly elevated risks as it is connected to an innovative, disruptive, and rapidly expanding technology; iii) the subject of the processing has a cross-border nature of global scope with practically uncontrollable effects on the data subjects; iv) the purpose of the processing falls within the core business of the Company; v) the number of Italian data subjects involved cannot be quantified with certainty, but, in general terms, it can be reasonably presumed to be very high, as information available on the Google App Store (Google Play) indicates that the application has surpassed 10 million downloads (suggesting that a similar figure, although not verifiable, could be recorded for downloads on the Apple Store), while academic sources (Shikhar Ghosh, Replika: Embodying AI, Harvard Business School, Faculty & Research) report that the Company had reached 10 million users as early as January 2022; vi) the nature of the data has involved, according to the very nature of the

chatbot (which still presents itself today as “an AI companion always ready to chat when you need an empathetic friend”), also special data and, in the absence of age verification mechanisms and data filtering systems, personal information relating to minors. The duration of the violation is significant as the app was released to the public in November 2017; indeed, the fact that the success of the chatbot is to be temporally placed in a later period does not constitute a factor capable of counterbalancing the assessment of high severity, as the end of the violation depended on and coincided with the urgent intervention of the Authority.

All violations must be considered negligent in nature. As stated by the Article 29 Working Party, in the guidelines concerning the application and prediction of administrative monetary penalties for the purposes of Regulation (EU) No. 2016/679, adopted on October 3, 2017, and adopted by the EDPB on May 25, 2018 (guidelines WP 253), intentional behavior refers both to awareness and to the intention (consciousness and will) to commit an unlawful act, while in negligent behavior, the intention to cause the violation is absent despite the failure to comply with an obligation.

diligence. The Court of Justice of the European Union (CJEU), in a recent ruling (judgment C-807/21 of December 5, 2023), established that it is the responsibility of the supervisory authority to demonstrate that a violation was committed with intent or negligence by the data controller, as only unlawful violations can lead to the imposition of an administrative monetary penalty. In this regard, it is specified that, while it is true that the CJEU has established in the aforementioned decision that Article 83 of the Regulation does not allow for the imposition of an administrative monetary penalty without confirming that such violation was committed with intent or negligence by the data controller (see para. 75), it is also true that the same Court has upheld the fundamental principle "ignorance of the law is no excuse," stating that "a data controller may be sanctioned for conduct falling within the scope of the GDPR if that controller could not have been unaware of the unlawful nature of its conduct, regardless of its awareness of violating the provisions of the GDPR" (see para. 76). This principle had already been articulated by the Court of Justice in another case (judgment C-601/16 of March 25, 2021, paras. 97 and 98), where it asserted that "a company may be sanctioned for conduct falling within the scope of Article 101, paragraph 1, TFEU if that company could not have been unaware of the anti-competitive nature of its conduct, regardless of whether it was aware of violating the competition rules of the Treaty (see, in this sense, judgment of June 18, 2013, *Schenker & Co. and others*, C 681/11, EU:C:2013:404, para. 37). It follows that the fact that such a company has incorrectly qualified its conduct in law, which forms the basis for the determination of the infringement, cannot have the effect of exempting it from the imposition of a fine, as it could not have been unaware of the anti-competitive nature of such conduct" (judgment of June 18, 2013, *Schenker & Co. and others*, C 681/11, EU:C:2013:404, para. 38). In this specific case, it is believed that Luka could not, at the time when its service was made available (also) to users located in the European Union and specifically in Italy, evade a duty of knowledge and application of the Regulation which, as is well known, protects a fundamental right provided for and protected by Article 8 of the Charter of Fundamental Rights of the European Union. In light of the circumstances of the specific case, the context in which the data controller operates, and the disruptive and rapidly expanding technology that characterizes its activities, it is believed that the non-compliance of personal data processing with EU law constitutes the negligence underlying the concept of fault and demonstrates the existence of such a subjective element on the part of the Company. Furthermore, such fault must be considered serious precisely because of the breadth and innovative nature of the service offered, which involves large-scale processing of personal data worldwide. For the purposes of quantifying the administrative monetary penalty, the aggravating factors referred to in Article 83, paragraph 2, letters d) and f) of the Regulation are relevant. Regarding the first aspect, the degree of responsibility of the data controller must be considered high due to the failure to adopt, at the time of the service launch, technical and organizational measures suitable for mitigating risks to the rights and freedoms of the data subjects and granting them the exercise of the prerogatives provided for in Chapter III of the Regulation. Regarding the second circumstance, concerning the degree of cooperation, it is noted that the Company, while having responded to the request for information, did not produce any defense memorandum following the notification of the contestation pursuant to Article 166 of the Code, thereby resulting in poor cooperation with the Authority. For the purposes of adopting the administrative sanction, account is taken, as a mitigating

factor, of the measures taken by the data controller to remedy the violation and mitigate its possible negative effects (Article 83, paragraph 2, letter f, of the Regulation), in particular:

- the updates to the privacy policy, both immediately following the provision 39/2023 and subsequently, particularly with reference to the latest version dated February 23, 2024, as described in the previous paragraph, although such updates are not considered exhaustive;
- the implementation of age gate mechanisms described in the previous paragraph, although not exhaustive.

Due to the aforementioned elements, evaluated in their entirety, in the absence of data regarding the total annual worldwide turnover of the previous financial year of the Company, it is deemed appropriate to determine, pursuant to Article 83, paragraph 3, of the Regulation, the total amount of the administrative monetary penalty at €5,000,000.00 (five million), equal to half of the maximum fixed penalty provided for by Article 83, paragraph 5, of the Regulation. This amount is determined as follows:

- pursuant to Article 83, paragraph 3, of the Regulation, considering the uniqueness of the conduct as it involves related processing for the reasons stated above, the amount of the monetary penalty for the most serious violation of Articles 5, paragraph 1, letter a), 12, and 13, of the Regulation is calculated in the...

measure of €3,000,000.00;

- the penalty is increased for the violation of

Articles 5, paragraph 1, letter a) and 6 of the Regulation by an amount of €1,000,000.00;

- the penalty is increased for the violation of

Article 5, paragraph 1, letter c) and Article 25, paragraph 1, of the Regulation by an amount of €1,000,000.00;

This administrative pecuniary sanction is considered, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

Given the particular sensitivity of the data processed, it is deemed that the accessory sanction of publication on the Garante's website of this provision should be applied, as provided for by Article 166, paragraph 7 of the Code and Article 16 of the Garante Regulation No. 1/2019; this in light of the nature and severity of the established violations, particularly considering that these are large-scale processing activities involving a high number of data subjects, the risks in terms of personal data protection associated with making available to the public a service based on innovative and complex technology in the absence of the necessary safeguards. Furthermore, there is considered to be a general interest regarding the topic of generative artificial intelligence that requires the broadest possible awareness of the Authority's position on the matter.

Finally, it is believed that the conditions set forth in Article 17 of Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Garante, are met for the annotation of the violations identified here in the internal register of the Authority, as provided for by Article 57, paragraph 1, letter u) of the Regulation.

ALL OF THE ABOVE CONSIDERED, THE Garante

pursuant to Article 57, paragraph 1, letter f), of the Regulation, declares the processing described in the terms of the motivation to be unlawful, carried out by Luka Inc., headquartered at 490 Post St Suite 526, San Francisco, California, United States of America, for the violation of Articles 5, paragraph 1, letter a) (with reference to both the principle of lawfulness and transparency), 6, 12, 13, 5, paragraph 1, letter c), 24, and 25, paragraph 1, of the Regulation and, consequently,

a) pursuant to Article 58, paragraph 2, letter d) of the Regulation, orders the Company, within thirty days from the notification of the provision, to bring its processing into compliance with the provisions of the Regulation, in particular to align the privacy policy with Articles 5, paragraph 1, letter a), 12, and 13 of the Regulation as well as to align the age verification system with Articles 5, paragraph 1, letter c), 24, and 25 of the Regulation, remedying the shortcomings respectively indicated in paragraphs 5 and 6 of this provision;

b) pursuant to Article 157 of the Code, orders the Company to communicate to the Authority, within sixty days from the notification of this provision, the initiatives undertaken in order to implement the corrective measure referred to in the preceding point; any failure to comply with the provisions of this

point may result in the application of the administrative pecuniary sanction provided for by Article 83, paragraph 5, of the Regulation.

ORDERS

Luka Inc., headquartered at 490 Post St Suite 526, San Francisco, California, United States of America, to pay the total amount of €5,000,000.00 (five million) as an administrative pecuniary sanction for the violations of Articles 5, paragraph 1, letter a), 6; Article 5, paragraph 1, letter a), 12, 13, 5, paragraph 1, letter c), 24, and 25, paragraph 1, of the Regulation, noting that the offender, pursuant to Article 166, paragraph 8, of the Code has the option to settle the dispute by paying, within sixty days, an amount equal to half of the imposed sanction.

ORDERS

a) the aforementioned Company, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €5,000,000.00 (five million), according to the methods indicated in the annex, within 60 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law No. 689/1981.

DISPOSES

a) the publication of this provision, pursuant to Articles 154-bis of the Code and 37 of Regulation No. 1/2019;

b) the application of the accessory sanction of publication on the Garante's website of this injunction order, as provided for by Articles 166, paragraph 7 of the Code and 16 of the Garante Regulation No. 1/2019;

c) the annotation of this provision in the internal register of the Authority - as provided for by Article 57, paragraph 1, letter u), of the Regulation, as well as by Article 17 of Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Garante - relating to the violations and the measures adopted in accordance with Article 58, paragraph 2, of the Regulation itself.

The Authority reserves the right to examine and verify in an independent procedure the aspects concerning the lawfulness of the processing carried out by Luka Inc., with specific reference to the legal bases for the processing of personal data related to the entire lifecycle of the generative artificial intelligence system underlying the Replika service.

Pursuant to Article 78 of the Regulation, as well as Articles 152 of the Code and 10 of Legislative Decree No. 150 of 1 September 2011, an appeal against this provision may be made to the ordinary judicial authority, by filing a petition with the ordinary court of the place where the data controller resides, within thirty days from the date of communication of the provision itself, or within sixty days if the appellant resides abroad.

Rome, 10 April 2025

THE PRESIDENT

Stanzione

THE RAPPORTEUR

Scorza

THE ACTING SECRETARY GENERAL

Filippi

GUARANTEE FOR THE PROTECTION OF PERSONAL DATA

AT today's meeting, attended by President Pasquale Stanzione, Vice-President Ginevra Cerrina Feroni, Board Members Agostino Ghiglia and Guido Scorza, members, and Acting Secretary General Claudio Filippi;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation, hereinafter referred to as the 'Regulation');

HAVING REGARD TO the Personal Data Protection Code (Legislative Decree No. 196 of 30 June 2003), as amended by Legislative Decree No. 101 of 10 August 2018, laying down provisions for the

adaptation of the national legal system to the aforementioned Regulation (hereinafter referred to as the 'Code');

HAVING REGARD TO Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at fulfilling the tasks and exercising the powers assigned to the Garante per la protezione dei dati personali (Italian Data Protection Authority), approved by Resolution No. 98 of 4 April 2019, published in the Official Journal No. 106 of 8 May 2019 and at www.gpdp.it, web doc. no. 9107633 (hereinafter 'Garante's Regulation No. 1/2019');

HAVING REGARD TO the documentation on record;

HAVING REGARD TO the observations made by the Secretary-General pursuant to Article 15 of Garante's Regulation No. 1/2000;

RAPPORTEUR Guido Scorza;

1. INTRODUCTION

The proceedings originated from an investigation initiated by the Garante of its own motion following the publication of press reports and preliminary fact-finding conducted on the Replika service (<https://replika.com/>), a chatbot with a written and voice interface developed and managed by the US company Luka Inc. (hereinafter 'Luka' or the 'Company') and based on a generative AI system. Replika is described as a chatbot that can improve the user's mood and emotional well-being by helping them understand their thoughts and feelings, track their mood, learn coping skills, reduce anxiety, and work towards goals such as positive thinking, stress management, socializing, and finding love. Replika creates a 'virtual companion' that the user can decide to set up as a friend, therapist, romantic partner, or mentor.

Replika uses a Large Language Model (LLM) system that is constantly fed and improved through interaction with users. For the purposes of this decision, 'generative artificial intelligence' means the field of artificial intelligence that focuses on creating new and original content from input data in response to user requests (prompts), through the use of predominantly neural algorithms. 'Neural network' means a standard computational model applicable in a wide variety of contexts that allows the recognition of objects, shapes, or patterns within a given data set (e.g., a human face in a photograph). Generative artificial intelligence algorithms are used in a wide range of applications, including the recognition and generation of images, voice or music tracks, text, and videos. An example of generative artificial intelligence is large language models. For the purposes of this measure, 'Large Language Model' means a probabilistic model of a natural language, such as English or Italian, based on the assumption that all natural languages are highly redundant and correlated; this gives LLM the ability to identify the word or symbol that is most likely to follow a given piece of data. practices in the industry, to ensure that the Replika chatbot does not provide harmful or inappropriate content to users, particularly minors;

- develop a user-friendly interface that allows users to easily report inappropriate content and provide feedback on their interactions with the chatbot;
- enhance the privacy policy to ensure clarity and transparency regarding the processing of personal data, including the legal basis for such processing and the rights of users.

The Company emphasized its commitment to protecting the privacy and safety of its users, particularly minors, and expressed its willingness to collaborate with the Garante to ensure compliance with applicable data protection laws.

3. Garante's Follow-Up Actions

Following Luka's responses, the Garante continued to monitor the situation closely. On 15 August 2023, the Garante issued a follow-up communication to Luka, requesting updates on the implementation of the measures outlined in decisions No. 39/2023 and No. 280/2023. The Garante reiterated the importance of ensuring that all necessary steps were taken to protect minors and vulnerable individuals from potential risks associated with the Replika service.

4. Conclusion

The Garante remains vigilant in its oversight of personal data processing activities, particularly those involving minors. The ongoing investigation into Luka's practices highlights the critical need for

compliance with data protection regulations and the safeguarding of vulnerable populations in the digital environment. The Garante will continue to take necessary actions to ensure that personal data protection laws are upheld and that users' rights are respected.

practice;

- ensure compliance with the Regulation by, among other things, updating the register of processing activities, reviewing and updating data protection impact assessments (DPIAs), and updating the privacy policy relating to the service, in order to increase transparency for users.

By letter dated 31 March 2023 (Reg. No. 55533/23), the Company requested the corrective measure of the temporary limitation imposed by urgent measure No. 39/2023 be lifted, specifying:

- that the Replika service was designed to limit the extent of personal data processing, in accordance with the principles set out in Article 5 of the Regulation, including i) minimising the collection of user registration data (name, email address, date of birth – to verify age – and any third-party login data); ii) the adoption of data retention and erasure procedures that strike a balance between the need to provide the user with a smooth experience and the need to minimise the personal information that remains accessible; iii) the design of proprietary artificial intelligence (AI) models to interact with users; iv) the non-sharing of user conversations with third parties other than the Company's essential service providers, who are bound by confidentiality obligations; v) the implementation of strict controls designed to limit access to personal data by its own staff; vi) the non-use of user conversations for advertising or marketing purposes;
- that it does not offer the service to minors and to base the processing of users' personal data on the legal basis of contract performance;
- that it implemented, following the provision of the Garante, several measures aimed at preventing minors from accessing the service in violation of the Company's terms;
- that it included its mobile application in the Apple App Store with an age rating of 17 or older, which is the highest age rating allowed by Apple;
- that it does not collect special categories of personal data, given that the sharing of special categories of personal data by users during their interaction with the chatbot is spontaneous and must therefore be qualified as covered by explicit consent to processing, in accordance with Article 9 of the Regulation;
- that it takes its data protection obligations seriously and has integrated data protection into the design of the service, in accordance with Article 25 of the Regulation, and that it will continue to 'develop and improve its policies and procedures to provide users with a consistent, secure and rewarding experience'.

With specific reference to the Garante's decision, the Company stated:

- that it promptly blocked access to the Replika service to individuals located in Italy;
- that it strengthened measures to prevent access to the service by minors under the age of 18, in particular by: i) introducing an age gate on all service registration pages requiring users to indicate a date of birth greater than or equal to 18 years of age in order to access the service; ii) providing for a 'cooling-off period', in line with the guidelines of data protection authorities and best practices, to prevent minors from entering a different date of birth when the system denies access to the service; iii) launching activities aimed at improving automated content control processes (reporting individuals likely to be under 18 and preventing use of the service until age verification is completed through more robust methods);
- that it updated its privacy policy to address the transparency issues identified by the Garante;
- that it continues to develop and fine-tune its content moderation practices to prevent harm to users, in particular by creating a trust and safety programme to prevent the chatbot from being involved in offensive or harmful conversations;
- that it restricted access to conversations of a sexual nature or relating to other adult content to users active at 1 February 2023 and made such conversations unavailable to new users;
- that it continues to endeavour to ensure compliance with the Regulation through the support of an external data protection consultant. The commitments undertaken by the Company include: i) updating and maintaining the Company's record of processing activities; ii) reviewing and updating data protection impact assessments (DPIAs), including documentation of data protection by design and by

default processes; iii) refining and reviewing the Company's security policies and procedures; iv) reviewing the Company's data protection governance (including the possibility of appointing a DPO following the expansion of the Company's activities in the European Union).

The Company, by letter dated 26 April 2023 (Reg. No. 68896/23), submitted a second request for lifting the corrective measure of the temporary limitation imposed by urgent measure No. 39/2023, reiterating the measures taken, as already explained in the previous letter.

The Company, in a letter dated 14 June 2023 (Reg. No. 93675/23), further to the discussions held at the hearing on 31 May 2023, reaffirmed that it had responded promptly to Decision No. 39/2023, immediately blocking access to Replika in Italy and implementing adequate measures in response to the issues raised by the Garante in the aforementioned measure. The Company also expressed its commitment to prevent users located in Italy from engaging in conversations of a sexual nature by providing, once the service is reactivated, two versions of Replika: a free version and a paid version containing romantic but not sexual content. According to the Company, the introduction of a paid 'romantic' version will require additional age verification based on the user's payment card details, in line with the latest market standards for age verification mechanisms.

In a letter dated 14 July 2023 (Reg. No. 109176/23), the Company announced that it had complied with the requests set out in points 1-6 of decision No. 280/23 and, in particular, stated:

1. in relation to the information referred to in point 1 of Decision No. 280/23, that it implemented an updated privacy policy in the registration process and prior to access to the service, and that this information would be displayed to Italian users upon reactivation of the service;
2. with reference to the age gate mechanism referred to in point 2 of Decision No. 280/23, that it implemented an age verification system on all registration pages and that this system would be applied upon reactivation of the service;
3. with reference to the cooling-off period referred to in point 3 of Decision No. 280/23, that it implemented a cooling-off period to prevent minors from attempting to access the service again by entering a different date of birth. This period—lasting 24 hours—is to be managed (i) by checking the credentials of a minor user's account and subsequently preventing them from entering a different date of birth and (ii) by installing a cookie to prevent minor users from re-entering a different date of birth from the same browser. The Company stated that this cooling-off period would be applied upon reactivation of the service;
4. with regard to the exercise of the rights referred to in point 4 of Decision No. 280/23, that it provides users with a simple and effective method for exercising their data protection rights, including the right to object to the processing of their personal data and the rights to request access, rectification and erasure of their data, and that this mechanism would be applied upon reactivation of the service;
5. with regard to the request to prepare a plan for the development of an age verification mechanism during registration referred to in point 5 of Decision No. 280/23, that it implemented processes to prevent access by minors under the age of 18, including a language analysis mechanism that requires users to reconfirm their age through the age gate process when users identify themselves as under the age of 18. If no date of birth that satisfies the age gate is provided, the user cannot access the service. The Company stated that such processes would be applied in Italy upon reactivation of the service;
6. with regard to the request to prepare a plan for the development of an age verification mechanism during the use of the service referred to in point 6 of Decision No. 280/23, the Company stated that it implemented features that allow users to report inappropriate content to prevent the Replika chatbot from presenting it again, such as the ability to flag specific responses as inappropriate and provide feedback on the user experience during the session. The Company stated that these features would be implemented in Italy upon reactivation of the service.

Luka submitted, together with the letter dated 14 July 2023, a copy of the privacy policy updated on 12 June 2023.

3. FACT-FINDING ACTIVITY

Parallel to the adoption of the precautionary measure, the Garante started gathering the info deemed necessary to carry out the fact-finding activity by sending a request for information, in line with Articles 58(1)(e) of the Regulation and 157 of the Code. By letter dated 6 April 2023 (Reg. No. 58925/23), the Garante sent a request for information to Luka asking for details on how Replika works (categories of personal data processed and source from which they are collected; method used for collection; how the data collected is processed; where the data is stored; security measures adopted; processing of user data for system training purposes or for other purposes pursued by Luka), the processing of users' personal data (legal basis; storage period; minimum age for accessing the service provided by Replika; DPIA; appointment of a representative pursuant to Article 27 of the Regulation; procedures for managing rights pursuant to Articles 12–22 of the Regulation; legal basis and guarantees of adequacy pursuant to Chapter V of the Regulation, where applicable; clarifications regarding automated processing pursuant to Article 22 of the Regulation), and age verification measures for access to the service on the date of notification of urgent measure No. 39/23.

accessing the service;

- it has implemented measures to verify the age of users to ensure compliance with the minimum age requirement;
 - it provides users with the option to delete their accounts and associated data at any time;
 - it informs users about their rights regarding personal data, including the right to access, rectify, delete, and restrict processing of their personal data;
 - it has appointed a Data Protection Officer (DPO) to oversee compliance with data protection regulations;
 - it conducts regular audits and assessments of its data processing activities to ensure compliance with applicable laws and regulations;
 - it has established procedures for handling data breaches, including notification to affected users and relevant authorities as required by law;
 - it provides training to its employees on data protection and privacy matters to ensure awareness and compliance;
 - it maintains a record of processing activities as required by applicable data protection laws;
 - it ensures that any third-party service providers engaged in processing personal data on its behalf are compliant with data protection regulations and have appropriate safeguards in place.
- service, nor did it clarify the legal basis for the processing of personal data for the purpose of training the AI models.

In relation to the lack of transparency regarding the processing of personal data, the Garante noted that the privacy policy failed to provide sufficient information to data subjects about their rights and the means to exercise them. Specifically, it did not adequately inform users about the right to access their data, the right to rectification, the right to erasure, and the right to object to processing. The information provided was deemed vague and insufficient for users to understand the extent of their rights under the Regulation.

Regarding the retention period of personal data, the Garante found that the privacy policy did not specify how long personal data would be retained or the criteria used to determine that period. This lack of clarity is contrary to the requirements set forth in Article 5(1)(e) of the Regulation, which mandates that personal data should be kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed.

In terms of the processing of special categories of personal data, the Garante highlighted that the Company did not provide adequate justification for the processing of sensitive data, such as data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership. The privacy policy did not indicate whether any such data was being processed or the legal basis for such processing, which is a requirement under Article 9 of the Regulation.

The Garante concluded that the Company had failed to comply with several key provisions of the Regulation, which resulted in the initiation of proceedings for corrective measures and potential sanctions. The Company was given the opportunity to respond to the allegations and provide any

additional information or documentation that may support its position regarding the processing of personal data through the Replika service.

The Garante emphasized the importance of compliance with data protection regulations to ensure the rights of data subjects are upheld and to maintain trust in the digital services provided by the Company.

Garante's decision, the Company indicated that it had introduced a new age verification system. However, the Garante noted that this system was not in place as of 2 February 2023 and therefore could not be considered compliant with the relevant regulations at that time.

In summary, the Garante alleged that Luka had potentially violated multiple articles of the Regulation, including Article 5(1)(a), Article 6, Article 12, and Article 13, due to the lack of legal bases for data processing, insufficient transparency in the privacy policy, and inadequate measures for protecting minors. The Garante emphasized the importance of compliance with data protection laws and the need for companies to ensure that their services are safe and appropriate for all users, particularly vulnerable populations such as minors.

****Adoption of the aforementioned decision and with specific reference to age verification, the data controller stated that it had implemented an age gate on all registration pages for the Services aimed at restricting access to users who are at least 18 years of age and that the age verification mechanism includes a 'cooling-off period' aimed at preventing users—once they have ascertained that it is impossible to access the service by entering their real personal data—from immediately entering a different date of birth that would allow them to access the service. The Company also stated that a process was being developed to use language analysis to identify and prevent the use of the Services by persons under the age of 18.****

****In light of the above, the Garante alleged that Luka had possibly infringed Article 5(1)(c), 6; 7; 8; 24 and 25(1) of the Regulation for failing to put in place appropriate systems to verify the age of individuals as at 2 February 2023.****

****4. EXISTENCE OF EU JURISDICTION AND COMPETENCE OF THE GARANTE****

****As a preliminary observation, the Garante considers it appropriate to address the issues relating to the applicability of European data protection legislation to the service offered by Luka and to its own competence, also taking into account the objections raised by the Company in its reply dated 8 May 2023 to the request for information sent by the Garante. Article 3 of the Regulation governs the territorial scope of application of the legislation, establishing different criteria depending on whether or not the data controller is established in the European Union.****

****In the first case (Article 3(1), known as the establishment criterion), the Regulation applies regardless of whether the processing is carried out in the Union or not, and competence is determined in accordance with the one-stop-shop mechanism, pursuant to Article 56 of the Regulation.****

****In the second case (Article 3(2), known as the targeting criterion), the Regulation applies to the processing of personal data of data subjects who are in the Union insofar as the processing activities relate to: i) the provision of goods or services to data subjects in the Union (Article 3(2)(a) of the Regulation); ii) the monitoring of the behaviour of data subjects located in the Union insofar as such behaviour takes place in the same Union (Article 3(2)(b) of the Regulation).****

****The Company stated in the above-mentioned letter that it has a single establishment in the European Union in the Netherlands, reporting that it has 'a group of employees located in the Netherlands, including a number of decision-makers involved in cross-border data processing for the development of LLM and of the product' and that 'the Company's employees located in the Netherlands are involved in decisions concerning the processing of personal data by the Company and the operation of LLM globally, including decisions concerning the minimum portion of users located in Italy'. The existence of a Dutch establishment in the European Union would entail the application of the one-stop-shop mechanism and the competence of the Dutch data protection authority as lead supervisory authority in cooperation with the authorities concerned.****

****However, this statement is not supported by any evidence. In fact, both in the privacy policy published on Replika's website as at 2 February 2023 (version updated on 5 July 2022) and in subsequent versions thereof (including the current version updated on 23 February 2024), there is no mention of an establishment of the company in the Netherlands; likewise, no mention can be found in the Terms of Service (neither in the version updated on 14 September 2022 nor in the current version, updated on 7 February 2023), which, on the contrary, states that Luka is 'a software company who designed and built Replika, incorporated in Delaware, and operating in San Francisco, CA'.****

****Furthermore, the statements in the letter of 8 May 2023 are extremely vague, as they do not even indicate the name and registered office of the company allegedly established in the European Union (thus making it impossible to carry out any checks in cooperation with the Dutch supervisory authority pursuant to Article 61 of the Regulation) and are not supported by any document evidence (e.g. the Dutch company's articles of association or chamber of commerce registration).****

****As things stand, therefore, the Garante considers that no evidence has been provided to effectively demonstrate the existence of an establishment of the Company in the European Union and, as a result, the applicability of the establishment criterion under Article 3(1) of the Regulation and of the one-stop-shop mechanism with the competence of the Dutch data protection authority.****

****In the present case, the existence of EU jurisdiction and the competence of the Garante must be ascertained on the basis of the targeting criterion set out in Article 3(2) of the Regulation: more specifically, it must therefore be ascertained, as a preliminary matter, whether the Replika service can be considered as offered to data subjects located in the European Union for the purposes of the applicability of point (a) of the aforementioned Article 3 of the Regulation.****
permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed ('storage limitation'); f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality').

Article 6 of the Regulation establishes the conditions for lawful processing of personal data, stipulating that processing shall be lawful only if and to the extent that at least one of the following applies: a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes; b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract; c) processing is necessary for compliance with a legal obligation to which the controller is subject; d) processing is necessary in order to protect the vital interests of the data subject or of another natural person; e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller; f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject.

The Garante found that Luka did not provide sufficient evidence of the legal bases for the processing operations associated with the Replika service, which was accessible to users in Italy as of 2 February 2023. This lack of clarity regarding the legal grounds for processing constitutes a violation of Articles 5(1)(a) and 6 of the Regulation, as it undermines the principles of lawfulness, fairness, and transparency that are fundamental to the protection of personal data.

5.2 ARTICLE 13 OF THE REGULATION

Furthermore, the Garante identified a breach of Article 13 of the Regulation, which mandates that data subjects be provided with specific information when their personal data are collected. This includes the identity and contact details of the controller, the purposes of the processing, the legal basis for processing, the recipients of the personal data, and the retention period for the data. As of 2 February 2023, Luka had not adequately informed users in Italy about these essential elements, thereby failing to comply with the transparency obligations set forth in the Regulation.

6. CONCLUSIONS

In light of the findings outlined above, the Garante concludes that Luka has infringed Articles 5(1)(a), 6, and 13 of the Regulation. The Company is required to take immediate corrective actions to ensure compliance with the Regulation, including the establishment of clear legal bases for its data processing activities and the provision of comprehensive information to data subjects in accordance with the requirements of the Regulation. The Garante will continue to monitor the situation and may impose further measures if necessary to protect the rights of data subjects and ensure compliance with the applicable data protection laws.

the legal basis for processing personal data related to the development of the LLM that powered the chatbot.

- The DPIA does not provide sufficient detail to demonstrate compliance with the legal requirements, particularly in relation to the specific processing activities and their corresponding legal bases.
- The documentation fails to clarify how the processing activities align with the principles of necessity and proportionality as mandated by the Regulation.

In conclusion, the Company has not adequately demonstrated that it has identified and documented the legal bases for its processing activities, particularly concerning the development of the LLM, which is a critical requirement under the Regulation. The lack of specificity in the privacy policy and the DPIA raises significant concerns about the legality of the processing activities conducted by the Company.

the purpose of 'Model Development' nor its legal basis in the table set out in paragraph 2;

- The DPIA, while distinguishing between the two processing purposes of 'Chatbot Interaction' and 'Model Development' (par. I) and analysing their respective legal bases (par. II), does not provide a clearly identified date and therefore does not demonstrate that the identification of the lawfulness conditions under Article 6 of the Regulation occurred prior to 2 February 2023. Moreover, the DPIA refers to legitimate interest as the legal basis for processing for the purposes of 'Model Development' without providing any arguments relating to the so-called 'three-step test' required in the legitimate interest assessment. Finally, it is pointed out that the DPIA, while being an excellent accountability tool, is not the document chosen by regulators for informing data subjects about processing activities; such information must instead be provided in the privacy policy.

With reference to Article 5(1)(a) of the Regulation, attention is drawn to the principle expressed by the EDPB in its binding decision 1/2021 on transparency—also applicable to the principle of lawfulness—according to which the principles set out in Article 5 of the Regulation must be considered as a general concept which is then implemented in various provisions and specific obligations (in the case of lawfulness, in Articles 6, 7, 8, 9 and 10 of the Regulation). Therefore, according to the EDPB, it is necessary to distinguish the specific obligations arising from a principle (in this case, Article 6 of the Regulation) from the principle itself as set out in Article 5 of the Regulation, since the principle

cannot be circumscribed to the specific obligation, although the specific obligation is a concretisation of the principle.

The principle of lawfulness is indeed an overarching principle that reinforces other principles (such as fairness and accountability). This is confirmed by Article 83(5) of the Regulation which allows for separate sanctions for infringing the lawfulness obligations independently of any breach of the principle itself. In this specific case, the Garante considers that there has also been an infringement of the principle of lawfulness referred to in Article 5(1)(a) of the Regulation, taking into account the gravity (lack of a clear and granular identification of the legal bases underpinning the different processing operations), the nature (this is an essential element of data processing) and the impact (this is a new type of processing connected to an innovative technology such as generative artificial intelligence) of the single specific infringement of the obligation referred to in Article 6 of the Regulation.

Based on the foregoing, the Garante considers that Luka failed, as at 2 February 2023, to identify the legal bases applicable to the different processing operations carried out through the Replika service, provided and made available to the public in Italy on that date, in breach of Articles 5(1)(a) and 6 of the Regulation.

With regard to the substantive analysis and evaluation of the legal bases under Article 6(1)(b) and (f) of the Regulation—allegedly relied upon for the use of the chatbot and the post-training of the LLM underlying the Replika service—and, more generally, the legal bases applicable throughout the entire lifecycle of the generative AI system developed by the Company, the Garante reserves the right to initiate a separate and autonomous investigation.

5.2 ARTICLES 5(1)(A), 12 AND 13 OF THE REGULATION

The Garante notified Luka of the infringement of Articles 5(1)(a), 12 and 13 of the Regulation for having provided, as at the date of 2 February 2023, a privacy policy concerning the Replika service which did not comply with the obligations and general principles on transparency established under the Regulation.

Article 5(1)(a) of the Regulation requires that personal data be processed lawfully, fairly, and in a transparent manner in relation to the data subject (principles of lawfulness, fairness and transparency).

Article 12 of the Regulation lays down rules regarding transparency and the modalities for the exercise of rights, while Article 13 specifies the information that a data controller must provide when personal data are collected from the data subject. On the subject of transparency, Recital 58 of the Regulation requires that any information addressed to the public or the data subject be concise, easily accessible and easy to understand, and that clear and plain language be used, and, with reference to the specific protection of children, it provides that 'where processing is addressed to a child, should be in such a clear and plain language that the child can easily understand'.

On the issue of transparency, the Committee's guidance is also relevant, particularly Guidelines 2/2019 on the processing of personal data under Article 6(1)(b) of the GDPR in the context of the provision of online services to data subjects, where it is provided that the legal basis for the processing must not only be identified at the outset of processing, but also explicitly specified in the 'information given to data subjects in line with response to the Garante's inquiries, stating that no personal data was transferred outside the EEA. However, the privacy policy did not reflect this clarification, leading to potential confusion for data subjects regarding the actual practices of the Company.

In conclusion, the Garante found that the privacy policy adopted by Luka on 2 February 2023 did not meet the requirements of fairness and transparency as mandated by the GDPR. The lack of availability in the local language, the incompleteness and inaccuracies of the information provided, and the misleading statements regarding data transfers constituted significant violations of the transparency obligations outlined in the Regulation. The Company is therefore required to take immediate corrective actions to ensure compliance with the GDPR and to provide clear, accurate, and accessible information to data subjects in the appropriate language.

letter of 8 May 2023 (Reg. No. 74173/23) concerning the applicability of the criterion of establishment in the European Union. It is therefore noted that the controller's own statements confirm the presence of misleading information;

- Section 6, 'Your data protection rights', while not expressly referring to Article 22 of the Regulation, provided specific information on that right, thus giving users the unfounded belief that their personal data were subject to automated decision-making. The absence of an automated processing within the meaning of Article 22 of the Regulation was confirmed by the data controller in its reply letter (Reg. No. 74173/23), where it claimed that 'although the chatbot relies on automated processes to generate responses, the Services do not make decisions based on profiling which produce legal effects on data subjects or similarly affect them within the meaning of Article

22 of the Regulation'. This again confirms, through the controller's own statements, the presence of misleading information.

With reference to Article 5(1)(a) of the Regulation, reference is made to the same binding decision of the EDPB mentioned in the previous paragraph (binding decision 1/2021), according to which transparency is to be regarded as a general concept which is then concretised in various provisions and specific obligations (e.g. Articles 12, 13, 14, 25 and 35). It is therefore necessary to distinguish the specific obligations arising from the principle of transparency (set out in Articles 12-14 of the Regulation) from the principle expressed in Article 5 of the Regulation, since although these obligations are a concretisation of the general principle, the latter has a broader scope.

The principle of transparency, in fact, is an

overarching principle that reinforces other principles (such as fairness and accountability).

This interpretation is confirmed by the fact that Article 83(5) of the Regulation allows for distinct administrative fines for infringing transparency obligations independently of any breach of the principle itself. In other words, the transparency obligations do not define the entire scope of the principle of transparency, it follows that a breach of the transparency obligations laid down in Articles 12 to 14 of the Regulation may also constitute a violation of the principle of transparency where such a breach is marked by elements of gravity and systematicity.

In the present case, the Garante considers that there has also been an infringement of the principle of transparency laid down in Article 5(1)(a) of the Regulation, taking into account the gravity (failure to provide information to the data subjects on the legal bases underlying the different personal data processing operations), the nature (lack of clear information on the essential elements of the processing, such as the legal basis, purpose, storage principle, transfer outside the EU) and the impact (this is a new type of processing connected to an innovative technology such as generative artificial intelligence) of the single specific infringements of the obligations under Articles 12 and 13 of the Regulation.

For the above reasons, the Garante considers that Luka infringed, as at the date of 2 February 2023, Articles 5(1)(a), 12 and 13 of the Regulation.

For the sake of completeness, it should be noted that subsequent technical investigations revealed that the

data controller updated the privacy policy for the Replika service again on 23 February 2024. In this latest version, certain inaccuracies previously

identified were rectified. Notably, the privacy policy in force at the date of adoption of this decision now granularly mentions the legal basis for each processing activity carried out by the controller and the type of data processed; it expressly clarifies that the service is exclusively intended for users over the age of 18, and contains no reference, not even implicit, to automated decision-making within the meaning of Article 22 of the Regulation. Nonetheless, the information provided under Articles 12 and 13 of the Regulation remains available only in English, does not include specific information on the personal data storage period or the criteria used to determine such a period, and may still mislead data subjects as to the possible transfer of their personal data to the USA.

5.3 ARTICLES 5(1)(C), 6, 7, 8, 24 AND 25(1) OF THE REGULATION

The Authority notified Luka of the infringement of Articles 5(1)(c); 6; 7; 8; 24 and 25(1) of the Regulation for failing to set up users' age verification systems as at the date of 2 February 2023.

Pursuant to Article 5(1)(c) of the Regulation:

'Personal data shall be adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed'.

Pursuant to Article 24(1) of the Regulation: 'Taking into account the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller shall implement appropriate technical and organisational measures to ensure and to be able to demonstrate that processing is performed in accordance with this Regulation.

Those measures shall be reviewed and updated where necessary'.

context of the ongoing proceedings. This delay in implementing necessary measures raises concerns about the Company's commitment to protecting the rights and freedoms of data subjects, particularly minors.

In conclusion, the Authority emphasizes that the Company must take immediate action to rectify these deficiencies and ensure compliance with the Regulation. This includes the establishment of robust age verification systems, the implementation of appropriate technical and organizational measures, and the adoption of safeguards that effectively protect the personal data of children and other vulnerable groups. Failure to do so may result in further regulatory actions and penalties as stipulated under the applicable legal framework.

the context of the temporary limitation measure, adopted as a matter of urgency on 2 February 2023. In particular, during the discussions that followed the adoption of the aforesaid decision and with specific reference to the age gate issue, the Company explained that it had introduced an age gate

across all registration pages of the Services restricting access to users over the age of 18 and which includes a 'cooling-off period' aimed at preventing users who are initially denied access based on their real personal data from immediately reattempting registration using a different date of birth. The Company also stated its intention to develop a process based on language analysis to detect and prevent use of the Services by individuals under the age of 18.

Prior to the Garante's intervention, therefore, all users—including minors—could register to and use the Replika service without being asked to undergo any age verification. As already clarified in the notice of infringement, in the Garante's view, the lack of a common standard capable of guaranteeing, with absolute certainty, the effectiveness of age verification systems, and the ongoing debate at European level on this issue, are not sufficient to exempt the data controller from its obligations, in particular the obligation to verify the user's actual capacity to enter into a contract, which is essential for its validity.

It follows from the foregoing that, as at 2 February 2023, the Company had not implemented, in accordance with Article 24 of the Regulation, the necessary measures to ensure that the processing of personal data at the time of registration for the Replika service complied with Articles 5(1)(c), 24, and 25 of the Regulation. In particular, the Company failed to implement technical and organisational measures 'which are designed to implement data-protection principles, such as data minimisation, in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation and protect the rights of data subjects'. As a result, personal data were processed in excess of what was necessary for the purposes of a service which, according to the declarations of the data controller and the documents on file, was intended to be offered only to users over the age of 18 years.

With specific reference to the infringement of Article 5(1)(c) of the Regulation, it should be noted that, in this case, the adoption of appropriate technical and organisational measures—by design—intended 'to implement data-protection principles, such as data minimisation', not only constitutes a core requirement under Article 25(1) of the Regulation, but also represents an additional element substantiating the infringement of the minimisation principle itself, in line with Recital 78 of the Regulation.

More specifically, the Company's failure to adopt appropriate measures to safeguard access to and use of the Replika service resulted not only in the systematic processing by Luka of personal data exceeding what was necessary for the intended purpose of the processing (i.e. providing the service to users over the age of 18), but also that such processing involved data concerning vulnerable individuals (children, even potentially under the age of 13) who, because of this shortcoming, combined with the innovative technology underlying the service and the highly sensitive nature of the interactions generated by the chatbot, were exposed to a particularly high risk.

The news reports that prompted the Garante to initiate its investigation—together with documented cases of self-harm associated with the use of the chatbot reported in foreign media and brought to the attention of the judicial authorities—support the Garante's allegations. On the basis of the principles expressed by the oft-referred to EDPB binding decision 1/2021, the gravity and impact of the infringements require due consideration, leading to the conclusion that both the infringement of the principle laid down in Article 5(1) of the Regulation and the specific infringement of the obligations under Articles 24 and 25(1) of the Regulation are substantiated.

The Garante, on the contrary, does not consider there to be sufficient grounds to establish an infringement—pursuant to Article 166(5) of the Code—of the provisions regarding the consent of minors, specifically the requirement of a positive act on the part of the child in relation to information society services, as set out in Articles 6, 7 and 8 of the Regulation. In particular, it should be noted that, as emerged during the preliminary investigation—contrary to what was erroneously stated in the version of the privacy policy dated 2 February 2023 (see § 5.2)—the Replika service was not, and is not, offered to minors. Consequently, the data controller was not required to comply with the obligation to identify a legal basis for processing operations which were presumed not to be carried out.

Based on the foregoing, the Garante considers that, as at 2 February 2023, Luka infringed Articles 5(1)(c), 24 and 25(1) of the Regulation. For the sake of completeness, it should be noted that, on the date of adoption of this decision, further technical assessments have revealed continuing deficiencies in the age verification system currently implemented by the controller; in the Company. Therefore, the Garante orders the Company to take the following corrective measures:

1. ****Information Obligations****: The Company must ensure that all users are provided with clear and comprehensive information regarding the processing of their personal data, in accordance with Articles 12 and 13 of the Regulation. This includes, but is not limited to, the purposes of processing, the legal bases for processing, and the rights of users.
2. ****Age Verification System****: The Company must implement a robust age verification system that effectively prevents users under the age of 18 from accessing the service. This system should include mechanisms to verify the age of users at the point of registration and when users attempt to change their date of birth in their profiles.
3. ****Compliance Timeline****: The Company is required to bring its processing operations into compliance with the Regulation within a specified period of three months from the date of this decision. The Garante will monitor compliance and may impose further sanctions if the Company fails to meet this deadline.
4. ****Reporting****: The Company must submit a report to the Garante detailing the measures taken to comply with this order within one month of the compliance deadline.
5. ****Ongoing Monitoring****: The Garante reserves the right to conduct follow-up checks to ensure that the corrective measures have been effectively implemented and that the Company remains compliant with the Regulation.

The Garante emphasizes the importance of protecting personal data, especially that of minors, and expects the Company to take these corrective measures seriously to prevent any future infringements. Failure to comply with these orders may result in further administrative fines or sanctions as provided under the Regulation.

This decision is made in light of the need to uphold the principles of data protection and to ensure that the rights of users, particularly vulnerable groups such as children, are adequately safeguarded. specific corrective measures.

In particular, as regards the information obligations, the Garante found that, as of today, Luka's privacy policy (latest version dated 23 February 2024) is still non-compliant with data protection legislation insofar as: i) it is available only in English; ii) it does not specify the storage periods of personal data or the criteria used to determine such periods; iii) it may still mislead data subjects as to the possible transfer of their personal data to the USA.

Therefore, pursuant to Article 58(2)(d) of the Regulation, the controller is ordered to bring the privacy policy into compliance with Articles 5(1)(a), 12 and 13 of the Regulation by remedying the above shortcomings.

Furthermore, regarding the age verification system, the Garante found that, at the date of adoption of this decision, the age verification system used by the controller does not comply with the principle of data minimisation and with the principles of privacy by design and by default, in that:

- after the user profile is created, users can change their date of birth in the 'My Profile' section without this being followed by any verification by the controller. As a result, children who initially provided a false date of birth to register could subsequently enter their real age and still retain access to the service;
- the 24-hour cooling-off period does not apply when the creation of the profile occurs while browsing in incognito mode; in fact, it appears that following an initial failed age check, users may still successfully complete the registration process by entering a different (even fictitious) email address;
- the controller has not implemented any language analysis mechanisms prompting users to reconfirm their age through the age gate process when there are clear indications that the user is under the age of 18, except in limited cases where the user provides specific inputs (i.e. they unambiguously declare

that they are under 18). Only in such cases, does the application prompt users to confirm that they are over 18.

However, the Garante positively noted the implementation by Luka of a function allowing users to flag certain conversations as inappropriate, although it was not possible to determine the effect of such reports.

In view of the above, pursuant to Article 58(2)(d) of the Regulation, the controller is ordered to bring the age verification system into compliance with Articles 5(1)(c), 24 and 25(1) of the Regulation by remedying the shortcomings identified above.

8. INJUNCTION ORDER FOR THE APPLICATION OF THE ADMINISTRATIVE FINE AND ANCILLARY PENALTIES

The Garante, pursuant to Articles 58(2)(i) and 83 of the Regulation and Article 166 of the Code, shall have the power to impose an administrative fine pursuant to Article 83, in addition to, or instead of corrective measures referred to in the same paragraph.

In determining the amount of the administrative fine, the Garante shall take into account the principles and interpretation provided by the EDPB in their Guidelines 4/2022 on the calculation of administrative fines under the GDPR, version 2.1, adopted on 24 May 2023.

Based on the arguments set out above, the Garante found that the following provisions of the Regulation have been infringed: Articles 5(1)(a) and 6; Articles 5(1)(a), 12 and 13; Articles 5(1)(c), 24 and 25(1) of the Regulation.

In the present case, it should first be noted that the Company engaged in a number of conducts leading to multiple infringements, as specifically outlined and substantiated in the preceding paragraphs. The infringements relating to the legal basis (Articles 5(2) and 6 of the Regulation), transparency (Articles 5(1)(a), 12 and 13), and the age gate (Articles 24 and 25(1)) may, under the principle of unity of action, be considered together under Article 83(3) of the Regulation, which provides that, if a controller or processor infringes several provisions of the Regulation for the same or linked processing operations, the total amount of the administrative fine shall not exceed the amount specified for the gravest infringement. Specifically, in relation to such infringements, it may be assumed that the processing operations are linked, as defined in paragraph 28 of the above-mentioned guidelines (a unitary conduct consists of several parts that are carried out by a unitary will and are contextually, spatially and temporally related in such a close way that, from an objective standpoint, they would be considered as one coherent action). Among the aforementioned infringements, the most serious is considered to be the infringement of transparency obligations, given that both Article 5(1)(a) (Principle of transparency) and Articles 12 and 13 (Rights of the data subject) are subject to the administrative fines laid down in Article 83(5) up to a maximum amount of €20 million or, in the case of an undertaking, up to 4% of the total worldwide annual turnover of the preceding financial year, whichever is higher.

Pursuant to Article 83(1) of the Regulation, the

****Administrative Fine Guidelines****

An administrative fine shall be effective, proportionate, and dissuasive in each individual case. According to the aforementioned guidelines, the EDPB has clarified that the calculation of administrative fines should commence from a harmonised starting point which forms the beginning for further calculation, in which all circumstances of the case are taken into account and weighed (see par. 46). The harmonised starting point should consider three elements:

- 1) the categorisation of the infringements by nature under Articles 83(4)–(6) of the Regulation;
- 2) the seriousness of the infringement;
- 3) the turnover of the undertaking (see par. 48).

As regards the first aspect, two infringements are found, in abstract terms, of a more serious nature (Article 83(5) of the Regulation) and one of a less serious nature (Article 83(4) of the Regulation). The first two concern the infringement of the legal basis and transparency, while the third concerns the infringement of Article 25 of the Regulation.

Regarding concrete seriousness, the elements to be taken into account are:

- a) the nature, gravity and duration of the infringement (Article 83(2)(a) of the Regulation);
- b) the intentional or negligent character of the infringement (Article 83(2)(b) of the Regulation);
- c) the categories of personal data affected (Article 83(2)(g) of the Regulation).

In this case, regarding the three infringements linked under the principle of unity of action (legal basis, transparency, and data protection by design and by default), the level of seriousness of the infringements must be considered high, given that:

- i) the nature of the infringements concerns two fundamental principles (accountability and transparency), namely, on the one hand, the controller's failure to demonstrate that it had identified the legal bases for processing prior to the commencement of such processing, and, on the other hand, the failure to provide appropriate information to the data subject, particularly regarding the purposes of the two distinct types of processing ('Chatbot Interaction' and 'Model Development'), and the involvement of data such as minors' data, in excess of what was necessary to achieve the service provision purpose;
- ii) the nature of the processing involves significantly high risks as it is linked to an innovative, disruptive and rapidly evolving technology;
- iii) the processing has a cross-border nature and global scope, with effects that are practically uncontrollable by data subjects;
- iv) the purpose of the processing falls within the core business of the Company;
- v) the number of Italian data subjects involved cannot be precisely quantified, but in general terms it can reasonably be presumed to be very high, as information available on Google's App Store (Google Play) shows that the application has exceeded 10 million downloads (suggesting a similar figure may exist, though not verifiable, for downloads via Apple Store), while academic sources (Shikhar Ghosh, Replika: Embodying AI, Harvard Business School, Faculty & Research) indicate that the Company had already reached 10 million users by January 2022;
- vi) the nature of the data has also involved special category data—considering the nature of the chatbot itself (which is still presented as 'an AI companion always ready to chat when you need an empathetic friend')—and, in the absence of age verification mechanisms and data filtering systems, personal information relating to underage users. The duration of the infringement is significant, given that the app was released to the public in November 2017; indeed, the fact that the chatbot's success materialised later in time does not counterbalance the judgement of high seriousness, since the end of the infringement was triggered by and coincided with the Garante's urgent measure.

All the infringements must be regarded as being unintentional. As stated by the Article 29 Working Party in the Guidelines on the application and setting of administrative fines for the purposes of Regulation (EU) 2016/679, adopted on 3 October 2017 and endorsed by the EDPB on 25 May 2018 (WP 253 guidelines), 'intent' includes both knowledge and wilfulness to commit a violation, whereas 'unintentional' means that there was no intention to cause the infringement, although there was a breach of the duty of care. The Court of Justice of the European Union (CJEU), in a recent ruling (Judgment C-807/21 of 5 December 2023), established that it is the responsibility of the supervisory authority to determine whether an infringement has been committed intentionally or negligently by the controller, as only an unlawful infringement constitutes a condition for an administrative fine to be imposed. In this regard, it should be noted that while the CJEU stated in the aforementioned judgment that Article 83 of the Regulation does not allow an administrative fine to be imposed without it being established that the infringement was committed intentionally or negligently by the controller (see par. 75), it also upheld the fundamental principle 'ignorantia legis non excusat', stating that 'a controller can be penalised for conduct falling within the scope of the GDPR where that controller could not be unaware of the infringing nature of its conduct, whether or not it is aware that it is infringing the provisions of the GDPR' (see par. 76). This principle had already been established by the CJEU in another case (Judgment C-601/16 of 25 March 2021, paragraphs 97 and 98) where it affirmed that 'an undertaking may be punished for conduct falling within the scope of Article 101(1) TFEU where that

undertaking could not have been unaware of the anticompetitive nature of its conduct, whether or not it was aware that it was infringing the competition rules of the Treaty (see, to that effect, judgment of 18 June 2013, *Schenker & Co. and Others*, C 681/11, EU:C:2013:404, paragraph...

responsibilities assigned to the Garante are met, and therefore, the publication of this decision is warranted. This publication is intended to inform the public and stakeholders about the Garante's stance on compliance with data protection laws, particularly in the context of emerging technologies and their implications for personal data processing.

In conclusion, the administrative fine imposed is deemed appropriate in light of the circumstances of the case, the nature of the infringements, and the need to ensure compliance with the Regulation. The decision reflects the commitment to uphold the principles of data protection and to promote accountability among data controllers operating within the European Union.

exercising the powers entrusted to the Garante, are met for recording the infringements identified herein in the Garante's Internal Register, as provided for by Article 57(1)(u) of the Regulation.

BASED ON THE FOREGOING, THE GARANTE pursuant to Article 57(1)(f) of the Regulation, declares unlawful the processing activities described and carried out by Luka Inc., based in 490 Post St Suite 526, San Francisco, California, United States of America, as set out in the reasoning, for infringing Articles 5(1)(a) (with regard to both the principles of lawfulness and transparency), 6, 12, 13, 5(1)(c), 24, and 25(1) of the Regulation and, consequently:

a) pursuant to Article 58(2)(d) of the Regulation, orders the Company, within thirty days of notification of this decision, to bring its processing activities into compliance with the provisions of the Regulation, in particular by aligning its privacy policy with Articles 5(1)(a), 12, and 13 of the Regulation, and aligning its age verification system with Articles 5(1)(c), 24, and 25 of the Regulation, remedying the shortcomings identified in paragraphs 5 and 6 of this decision, respectively;

b) pursuant to Article 157 of the Code, orders the Company to inform the Authority, within sixty days of notification of this decision, of the initiatives undertaken to implement the corrective measure referred to in the preceding point; failure to comply with the provisions set out in this point may result in the imposition of the administrative fine provided for in Article 83(5) of the Regulation

ORDERS

Luka Inc., based in 490 Post St Suite 526, San Francisco, California, United States of America, to pay the sum of EUR 5,000,000.00 (five million) as an administrative fine for infringing Articles 5(1)(a) and 6; Articles 5(1)(a), 12, 13, 5(1)(c), 24 and 25(1) of the Regulation, stating that the infringing party, pursuant to Article 166(8) of the Code, has

the right to settle the dispute by paying, within sixty, an amount equal to half the imposed fine.

REQUIRES

a) the aforesaid Company, in the event of failure to settle the dispute pursuant to Article 166(8) of the Code, to pay the sum of EUR 5,000,000.00 (five million), according to the modalities indicated in the annex, within sixty days of notification of this decision, under penalty of the adoption of the consequent executive actions pursuant to Article 27 of Law No. 689/1981.

PROVIDES

a) that this decision be published, pursuant to Article 154-bis of the Code and Article 37 of the Garante's Regulation No. 1/2019;
b) that the application of the ancillary penalty of the publication of this injunction order on the Garante's website, as provided for by Article 166(7) of the Code and Article 16 of the Garante's Regulation No. 1/2019, be applied;
c) that this decision be recorded in the Garante's Internal Register—as laid down in Article 57(1)(u) of the Regulation and Article 17 of the Garante's Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at performing the tasks and exercising the powers entrusted to the Garante—regarding infringements and measures adopted in compliance with Article 58(2) of the Regulation.
The Garante reserves the right to investigate and assess in a separate and autonomous proceeding, the aspects concerning the lawfulness of the processing operations carried out by Luka Inc., with specific reference to the legal bases for processing applicable throughout the entire lifecycle of the generative AI system underlying the Replika service.
Under Article 78 of the Regulation, Article 152 of the Code and Article 10 of Legislative Decree No. 150/2011, this decision may be challenged before the ordinary judicial authority, by lodging an appeal with the ordinary court of the controller's place of residence, within thirty days from the date the decision was notified, or within sixty days if the appellant resides abroad.

Rome, 10 April 2025

THE PRESIDENT

Stanzione

THE RAPPORTEUR

Scorza

THE ACTING SECRETARY GENERAL

Filippi